

Received 22 August 2024, accepted 19 September 2024, date of publication 26 September 2024,
date of current version 14 October 2024.

Digital Object Identifier 10.1109/ACCESS.2024.3468379

APPLIED RESEARCH

Cybersecurity Risk Management and Evaluation Framework of Blockchain Identity Management Systems in HIoT: Experts Evaluation

BANDAR ALAMRI¹, ITA RICHARDSON², AND KATIE CROWLEY³

Department of Computer Science and Information Systems(CSIS), University of Limerick, Limerick, V94 T9PX Ireland
Lero, Science Foundation Ireland Research Centre for Software, University of Limerick, Limerick, V94 T9PX Ireland
Health Research Institute (HRI), University of Limerick, Limerick, V94 T9PX Ireland

Corresponding authors: Katie Crowley (Katie.Crowley@ul.ie) and Bandar Alamri (bandar.alamri@ul.ie)

This work was supported in part by the Ministry of Education of Saudi Arabia, and in part by the Science Foundation Ireland to Lero—Science Foundation Ireland (SFI) Research Centre for Software under Grant 13/RC/2094 and Grant 13/RC/2094_P2.

This work involved human subjects in its research. Approval of all ethical and experimental procedures and protocols was granted by the Faculty of Science & Engineering Research Ethics Committee at University of Limerick, Ireland, under Application No. 2023_02_05_S&E.

ABSTRACT This paper presents an evaluation of a cybersecurity risk management and evaluation framework for Blockchain-based Identity Management Systems (BC-IdM) in the Health Internet of Things (HIoT). In this paper, thirteen experts were interviewed using a Delphi method to evaluate the framework, which includes the factors that are used to evaluate any HIoT BC-IdM system and the cybersecurity risk management processes and activities that should be applied. In addition, the Simple Multi-Attribute Rating Technique (SMART) was used in the interviews and questionnaires with the experts to assign weights to the twenty-six identified evaluation factors to rank them based on their importance. The identified factors are divided into four main categories: security and privacy, technical, HIoT-related considerations, and external aspects. This paper shows that the security and privacy factors are the most important among other factors. Using Delphi, an agreement on the details of the framework was sought, including the cybersecurity risk management processes and activities in the main phases: framing, assessment, responding, and mentoring of risks. This article identifies the main and subcategories of the evaluation factors and explains the framework content in detail. It presents recommendations and findings concerning Blockchain-based Identity Management Systems in Health Internet of Things. The framework plays a role in standardizing BC-IdM in HIoT and contributes to the applicability and reliability of such systems by considering security, privacy, technical, HIoT-related, and external considerations.

INDEX TERMS Blockchain, cybersecurity risk management, Delphi, evaluation, health IoT, identity management, multi-criteria decision making.

I. INTRODUCTION

HIoT systems collect and transmit Personally Identifiable Information (PII) between stakeholders in healthcare settings providing real-time monitoring. Based on the use cases, they consist of different stakeholders, including, people, objects, systems, information resources, and services. Although HIoT

systems bring benefits to individuals, communities, and organizations, they pose several security risks. Therefore, the security of the Identity Management (IdM) system must be considered [1]. Classical IdM systems are prone to a single point of failure. This is critical in healthcare systems. Finding a solution to the single point of failure in healthcare systems is a priority as it impacts patient safety. Therefore, several research studies have been conducted on using Blockchain technology to replace the classical IdM systems in use, i.e.,

The associate editor coordinating the review of this manuscript and approving it for publication was Wei Quan.

centralized and federated IdM systems. Blockchain (BC), as a decentralized paradigm, has the potential to solve the single point of failure that exists in conventional IdM systems. However, based on previous findings, there is a lack of cybersecurity risk management and evaluation framework of the BC-IdM solutions in general and particularly in the Health Internet of Things (HIoT) [2]. In three previous works [1], [2] [3], we reviewed the BC-IdM solutions proposed for HIoT, identified the security and privacy threats in such systems, and proposed a high-level cybersecurity risk management framework for HIoT BC-IdM systems. Moreover, in terms of the general evaluation of the BC-IdM systems, we identified the evaluation factors for such systems. Standards-oriented cybersecurity risk management is a fundamental factor in the reliability of HIoT and other IoT applications [4]. It is essential to follow security risk management standards and build suitable frameworks for BC-IdM. Even if an organization uses the best software/hardware protection but does not follow general security guidelines and standards, protocols, and rules, the IdM system is put at risk. Moreover, cybersecurity is one aspect that must be evaluated before adopting such systems in healthcare systems, such as HIoT applications. To evaluate the cybersecurity risk management framework and the evaluation factors, in this paper, we interviewed experts from BC, IdM systems, HIoT security, and cybersecurity risk management domains. The interviews followed the Delphi method, where the interviewees were contacted in two rounds to get a consensus regarding the framework's main phases, steps, and evaluation factors. This process resulted in enhancing the framework details and assigning weights to the identified evaluation factors using a Multi-Criteria Decision Making (MCDM) technique. The combined framework will help cybersecurity assessors and decision-makers make the best decisions concerning the BC-IdM systems in HIoT.

The structure of the rest of this paper is as follows: Section II covers the background, Section III addresses the related works, an overview of the current state of the literature and the related papers to this work, Section IV explains the research methodology, Section V presents the results, Section VI describes the developed framework in detail, VII includes the discussion, limitations and future work are covered in Section VIII, and Section IX covers the article conclusion.

II. BACKGROUND

A. BLOCKCHAIN TECHNOLOGY

BC is defined as a distributed digital database shared between a number of network participants based on cryptography and consensus mechanisms and protocols. Characteristics such as decentralization, anonymity, immutability, transparency, and auditability distinguish it from other technologies and paradigms. The first application that was based on BC was Bitcoin, which was initially pioneered when Satoshi Nakamoto published a white paper in 2008 titled "Bitcoin: A Peer-to-Peer Electronic Cash System." The paper described

how it would be possible to transfer money from one user to another without a third party using a cryptographic mechanism to fulfill this task. After one year, an open-source software implementing Bitcoin was launched [5]. Although BC is now used outside of financial applications where digital transactions are exchanged, its core technology is very much related to Bitcoin and cryptocurrency concepts. The Bitcoin decentralized payment system is based on a cryptographic proof mechanism instead of relying on trusted third parties. This mechanism uses a public/private key authentication process for validation. After the transaction is shared with all other nodes in the network and gets validated, it is added to the public ledger. There are two steps to validate such a transaction; first, to ensure the sender owns the cryptocurrency, and second, to ensure that the sender has a sufficient balance in their account. In order to avoid duplication in spending cryptocurrencies, there needs to be a mechanism that helps Bitcoin to organize and ensure this process. To solve this issue, Bitcoin made use of the concept of BCs where a group of chains are connected with each other by hashes creating the BC network. Every block has a group of transactions that are meant to be added to the network at the same time. However, there is still a need for a mechanism in charge of organizing the process of mining the blocks in a timely manner. From here, the role of the Proof-of-Work (PoW) consensus mechanism starts. PoW is based on a mathematical puzzle where nodes are tested by other nodes to be allowed to add their transactions in the right order in a process called mining [6]. Ethereum BC and Smart Contracts were launched in 2013, paving the way for using BC in non-financial applications. In more recent years, the attention of developers and researchers shifted to proposing applications based on BC in different domains. Recently, some big technology companies like Microsoft and IBM have offered BC as a service [7]. There are three main categories of BC technologies:

- (A) Public or permissionless BC, data in Public BC are public for all nodes in the network, and all nodes are allowed to take part in the consensus process.
- (B) Private, or permissioned BC: access to data in Private BC is restricted only to the participants of the BC network from the same organization.
- (C) Consortium BC which is a hybrid of public and private BCs is another emerging type of BC technologies, where access to data is restricted to participants from different organizations.

BC consists of a set of blocks that are connected with each other using block headers. The blocks include data transactions, which can be accessed by nodes using digital signatures through private/ public keys owned by users. BC structure includes the following layers, as shown in Table 1 [8].

1) CONSENSUS AND INCENTIVE MECHANISMS

Censuses mechanisms are one of the main parts of any BC technology. They are at the core of BC applications. They

TABLE 1. BC layers.

BC layer	Description
Application Layer	Includes applications built upon BC, such as BC-IdM systems.
Smart contract Layer	SC (also known as chaincode) used in the BC application.
Incentive Layer	Includes consensus mechanism used in the BC application.
Network Layer	Peer-to-Peer (P2P) network used in the BC technology.
Data Layer	It includes data such as transaction data, Hashes, and digital signatures.

are used to ensure the functionality of the BC processes and the security of its data by providing an agreement on the addition process of the validated transactions. Using it alongside cryptography and incentive mechanisms trust is built in the BC. They are based on the idea of having a common interest between participants to keep Blockchains running and secure. They set rules for participants to follow. A several number of consensus mechanisms are used in BC. The most common mechanisms are explained in Table 2.

TABLE 2. Consensus mechanisms.

Consensus mechanism	Description
Proof of Work (PoW)	The most used mechanism. It is based on solving mathematical puzzles in order to mine the transaction. It needs considerable computational process “work” in order to solve the problem. It is used in BC technologies like Bitcoin.
Proof of Stake (PoS)	It solves the resource consumption issues in PoW. It is based on rewarding block creator nodes with their built coins stakes, or giving them a penalty in the case of misbehaving. It is used in the new version of Ethereum BC.
Delegated Proof-of-Stake (DPoS)	This consensus mechanism is based on a voting system for voting for delegates to validate transactions. It is used in BC such as Bitshares BC.
Practical Byzantine Fault Tolerance (PBFT)	In PBFT a correct consensus can be reached if the bad node number does not exceed a third of the total number of nodes participating in the transactions validation process. It is used in BC such as Hyperledger Fabric.

Incentive mechanisms are important parts of BC to keep the BC application functioning and secure. They are used to encourage nodes to participate in the mining and validation processes. Varied incentive mechanisms are used in consensus mechanisms. For example, new coins are paid to the winner of mining the transaction. In PoS the winner gains transaction fees. While in DPoS, miner nodes are encouraged by the threat of losing their reputation and income as a result. On the other hand, in the PBFT consensus mechanism, there are no incentive mechanisms used as the mining process is done in permissioned/ consortium BC by known participants such as Hyperledger Fabric BC [9].

2) BLOCKCHAIN CRYPTOGRAPHY

Cryptography plays an essential role in BC technologies in order to create trust between parties within the network. Using cryptography in BC eliminates the need for a centralized authority. Information is stored securely in the BC ledger using cryptography techniques, such as Public Key Cryptography, Hash Functions, and Zero-Knowledge-Proof [9].

3) SMART CONTRACTS

An integral part of BC which provides programmed rules to the events in BC applications. It is initially used in Ethereum BC and then widespread among varied BC technologies for features, such as accuracy, autonomy, and cost-saving. It is a program used to set a set of rules for the decision points in the BC applications, in which all transactions follow and comply with the same rules. Several programming languages are used to program SC. The most common one is Solidity [9].

4) BLOCKCHAIN PLATFORMS AND APPLICATIONS

There are a number of BC platforms besides Bitcoin and Ethereum; the Hyperledger Fabric BC is one of the most attractive BC platforms recently used for non-financial applications [10]. On the other hand, there are other distributed-ledger technologies like IOTA, which are similar to BC technology but different in that they are based on the Tangle data structure rather than blocks and use a different validation process to add new transactions. IOTA is an evolving peer-to-peer network based on consensus protocols, which has potential benefits in IoT applications. However, it is under development and does not support Smart Contract at the moment [11]. BC is a disruptive technology that, for its profound benefits, is widely used in different domains and applications. The trend shows that it attracted researchers' attention after its platforms became available beyond financial and cryptocurrency applications. According to Zou et al. [12], since 2017, the application of BC in different domains like healthcare and IoT has increased dramatically. In particular, applications of BC in the healthcare domain are increasing significantly because it is stated to be a better choice for managing sensitive data [13]. Several Blockchain-based applications are proposed in healthcare, such as HIoT decentralized IdM systems, EHR, and PHR data sharing and management. All BC-based applications in healthcare strive to manage health data securely. According to the literature, two groups of health data can be stored in BC: (1) Self-reported data, which are produced from remote monitoring systems, such as HIoT, and, (2) health data located in health information systems databases, such as data stored in HER and PHR. The potential success of patient data management systems using BC leads to more advanced applications of BC in healthcare, such as BC-based HIoT data management [14], e.g., BC-IdM HIoT systems. In such systems, BC is used to provide a decentralized IdM system

to eliminate the need for a trusted party and allow HIoT user to have control over access to their data, which as a result increases HIoT system security and privacy. BC-IdM systems are one of the emerging IdM systems with the potential to improve the privacy of HIoT devices and users' security and privacy [15]. However, according to Wang et al. [8], as the number of BC application studies is rising, the number of discovered attacks in BC-based applications is increasing, leading to a huge economic loss. According to [16], there is still a shortage of studies that address the security challenges around BC.

B. IdM SYSTEMS AND BC-BASED IdM SYSTEMS

IdM systems are crucial for the security of data in information system applications [17]. IdM can be defined as a security system used to manage the life-cycle of digital identities to ensure that only authenticated identities can be authorized to access data assets in a system. An IdM system consists of two primary operations. The first is authentication (AuthN), a process that verifies identity, thus preventing malicious access to a system. AuthN ensures that a claim of identity ownership by using either digital (e.g., public-key cryptography) or physical (e.g., biometrics) authentication methods. The second is authorization (AuthZ), a process ensuring that only legitimate users can access specific data assets using access control mechanisms. After authenticating an identity, there is a need to control the access to process data. The AuthZ operation is responsible for denying or granting user access to data, which is achieved by first defining policies (set of rules) and then using and applying access control methods [18]. Five access control models manage user access rights to data in traditional IdM: mandatory access control, discretionary access control, role-based access control, attribute-based access control, and capacity-based access control. Based on these models, rights are given to identities or users according to their roles and attributes. There are several access management standards used to fulfill the access control AuthZ and AuthN processes, such as OpenID Connect, open authorization, security assertion markup language, and extensible access control markup language [19]. Based on the AuthN and AuthZ operations, IdM guarantees secure access to systems. Identities are managed in the whole life-cycle of the IdM system based on the IdM model category. There are three forms of IdM systems [20], as follows:

- **Traditional IdM:** in this model, an entity (users, things, organizations) authenticates to a system (relying party) using credentials separately. The credentials are stored by the relying party, from which they give access and privileges to entities. Users in this model need to sign up differently for every system they use.
- **Federated IdM:** in this model, a user deals with a service provider that manages the identity and access process on behalf of relying parties (i.e., business system). Although this model facilitates the identity and access

management process between users and relying parties, they pose security and privacy concerns, such as service provider misuse of user credentials and the single point of failure security issue.

- **User-centric IdM:** BC-IdM systems can provide this type of IdM model where a user does not need to rely on a trusted third party (TTP) in order to access a system's services. This type of IdM system can solve the issues addressed in the traditional and federated models.

BC is broadly used for leveraging Self-Sovereign Identity (SSI) management systems, i.e., BC-based IdM systems. The most common BC-IdM applications are uPort, Sovrin, and ShoCard, which attracted an investigation of their security aspects by researchers [21]. Moreover, several studies have also applied Blockchain for developing decentralized IdM systems in HIoT. These studies were reviewed and analyzed in [2]. BC-IdM systems promise to provide a user-centric IdM system that allows identity owners (i.e., data subjects) to have control over their digital identity and data, e.g., SSI. SSI IdM systems are decentralized BC-IdM built upon the BC network, on-chain and off-chain technologies [22]. BC has been used widely for proposing IdM systems, which are based on two IdM models, Self-Sovereign Identity (SSI) and decentralized trusted identity [23]. According to Taylor et al. [24], in a systematic review conducted on using BC for security purposes, 45 percent of studies focused on IoT applications for AuthN purposes.

BC-IdM for HIoT systems is a complicated system that consists of many primary and secondary assets. Our previous work [2] has shown the broad use of BC-based IdM in HIoT, the main technologies and components of such systems, and some of the security and privacy risks that such systems could involve. The main architecture for BC-IdM for HIoT systems consists of the user, application, BC, off-chain, connectivity, and HIoT device layers. IdM system functions mainly work in the BC layer with complementary technologies in off-chain and connectivity layers, especially external storage, such as the Interplanetary File System (IPFS), Application Programming Interfaces (APIs), and cloud technologies.

The IdM system is the main security asset of HIoT BC-IdM and is at the core of this study. The high-level architecture proposed by [20] for BC-based IdM systems involves the following layers and components, as shown in Table 3:

HIoT BC-IdM systems' identities differ from standard systems that do not involve IoT devices. In HIoT systems, the HIoT identity is a vital part of the IdM system; thus, AuthN needs to be guaranteed for these identities. Organizations such as W3C and Decentralized Identity Foundation (DIF) proposed emerging standards for BC-based IdM systems, which are used by researchers in applications, such as HIoT. Table 4 includes the most common BC-IdM system standards [20].

III. RELATED WORK

Although the maturity of BC applications in healthcare is increasing, its implementation is still immature and

TABLE 3. BC-IdM system layers.

Layer	Description
Blockchain	BC technologies are IdM-specific, such as Indy Hyperledger- or Smart Contract-supported platforms, such as Ethereum and Hyperledger Fabric, which are used to facilitate Public Key Infrastructure (PKI) to ensure data integrity in the IAM system.
Second-layer protocol	Offload solutions for scalability by proposing a top layer, where Smart Contracts and other technologies are used in the IdM system.
Smart Contracts	The majority of BC-based IAM build their logic based on Smart Contracts.
Credential storage methods	Off-chain storage where credentials are stored, as not all BC-based IdM systems provide on-chain storage for credentials.
User-controlled identity wallets	Applications with APIs are used by users to store identifiers, credentials, and their corresponding private keys and allow entities to exchange credentials and presentations with each other.
User-profile data management protocols	External protocols are used for storing user profile data, such as browsing data, user settings, and transaction history.
Data exchange models	Data exchange models, such as JSON, SAML, XDI, and JWT are used to initiate, verify, and disclose data, such as credentials and representations.
Application libraries and interfaces	APIs and applications allow communication between IdM roles (i.e., requester, issuer, relying party, and verifier).

TABLE 4. BC-IdM system standards.

Standard	Description
Decentralized Identifiers	W3C develops Decentralized Identifiers (DIDs) to facilitate private channels between entities, eliminating the need for a central registration authority.
Verifiable Credentials and Verifiable Presentations	Verifiable Credentials (VC) and Verifiable Presentations (VP) are standards developed by W3C used to format credentials.
Universal Resolver	It is developed by the Decentralized Identity Foundation (DIF) to retrieve DID documents.
Identity Hubs DID Auth–RWOT	Off-chain storage developed by DIF. Authentication framework to ensure DID ownership.

is in the early stages (i.e., proof-of-concept stage). The reason for this is the lack of feasibility and scaling of BC for healthcare organizations [25]. General evaluation of new BC applications in healthcare covering BC technical, organizational, legal, and multiple other aspects before adopting them is needed and is essential in any change process [26]. Therefore, we investigated the HIoT BC-IdM system security and functionality situation in [2], proposed BC cybersecurity risk management framework in [1], and in [3], we identified the evaluation factors of BC-IdM systems. In [2], we reviewed the BC-IdM solutions that are proposed for HIoT applications. In that work, we identified twenty-four peer-reviewed studies in which BC-based AuthN and AuthZ solutions were proposed for HIoT. The reviewed

studies focus was on utilizing the decentralized feature of BC platforms such as Ethereum, Hyperledger Fabric, and Hyperledger Indy, which provide features such as privacy, transparency, and integrity, showing the potential of BC-IdM systems. However, findings from that study showed that there is a lack of a comprehensive cybersecurity framework used to assess the security and privacy risks of such systems. We also identified the high-level architecture for BC-based IAM systems in HIoT applications, in which some of the security and privacy threats exist. In another study [1], we conducted an extensive review study on cybersecurity risk studies on BC, IdM, and HIoT systems (106 studies). In that study, we designed a cybersecurity taxonomy for HIoT BC-IdM studies, a comprehensive cybersecurity framework, showing requirements, threats, vulnerabilities, attacks, controls, and countermeasures of the layers of the HIoT-BC-IdM systems, and proposed a cybersecurity risk management framework for HIoT BC-IdM systems. None of the reviewed studies covered the cybersecurity risks of BC-IdM systems in particular; however, every study focuses on one of the main assets, either, BC, IdM, or HIoT, which contributed to developing the proposed framework. In our latest work [3], we reviewed thirty-four studies that proposed evaluation factors of BC and BC-IdM systems, and as a result, we identified the BC-IdM ecosystem components and evaluation factors, classified into security and privacy, technical, external, and domain-related evaluation factors (e.g., HIoT). We focused more on the evaluation factors for HIoT BC-IdM systems. While the research problem was investigated in [2], framework versions 1 and 2 were produced from [1] and [3], respectively.

Before conducting the evaluation stage in this work, the framework consisted of the cybersecurity risk management framework processes and evaluation factors identified previously. Therefore, in this article, we focus on evaluating the findings identified from our three previous published works using a reliable and well-known method (Delphi). The significance of this final product relies on the evaluation from experts in the field, which is exactly the contribution of this work. By doing this, we answered the main research question for the whole research, “What is a reliable cybersecurity risk management and evaluation framework for BC-based IdM in HIoT?”.

IV. RESEARCH METHODOLOGY

The aim of this study is to evaluate our previously developed and published cybersecurity risk management and evaluation frameworks of HIoT BC-IdM systems. We presented the developed framework to experts to get feedback on the components of the framework. Figure 1 below shows the research methodology followed in this study.

The Delphi method and Simple Multi-Attribute Rating Technique (SMART) were used together as MCDM techniques to evaluate the developed framework with thirteen experts from IdM, BC, HIoT security, and cybersecurity risk management domains and to revise and assign weights to the identified evaluation factors. Interviews and questionnaires

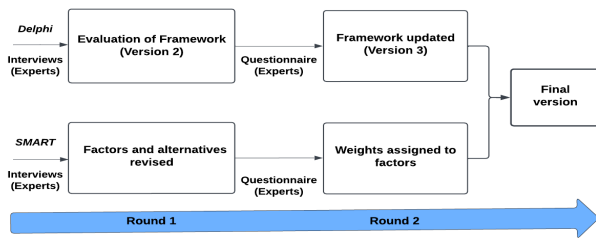


FIGURE 1. Research methodology.

were used as data collection methods in this study. The research strategy, the interviews and questionnaires design and plan, research ethics, analysis techniques, Delphi, and SMART methods are explained in the following subsections.

A. RESEARCH METHODOLOGY STRATEGY

Delphi is the main research method used in this survey study. Mixed qualitative and quantitative research techniques are used to accomplish the objective of this study. The Delphi method [27] is described as an MCDM technique used to structure communications between a group of experts. It usually runs over two phases or more to reach a consensus among experts. It can be run face-to-face using online meetings or questionnaires and can be done in group work or via individual meetings. We conducted two rounds in this study as explained below.

- First, we used a qualitative interview method, with experts from four domains related to the system under study, i.e., HIoT BC-IdM systems, on the developed framework's main components using seven open-questions for each group of experts.
- Second, we used a questionnaire method with the participants in the Second Round of Delphi. In the questionnaire, we sought the participants' final feedback on the combined framework components and assigned weights to the evaluation factors. MCDM methodology techniques, i.e., the Delphi and SMART, were used together in this study. The SMART technique is used beside Delphi to help the research sample assign values to the identified factors, which will help the decision-makers and users of the developed framework to select between the BC-IdM solutions alternatives.

According to [28] the survey research strategy should include the following five elements:

1) REQUIRED DATA

Making a decision on which required data is sought from participants is a major step of the survey research strategy. Three types of data are planned to be obtained from the research participants. First, experts provide feedback on the main phases and sub-steps of the developed framework. Second, they provide the final technical views on the framework. Third, they assigned weights to the identified evaluation factors.

2) DATA COLLECTION METHOD

We use two data collection methods in this study: interviews and questionnaires. Interviews are often used to elicit the theme of a followed questionnaire. Individual semi-structured interviews are used in the study where the researcher prepared seven questions for every group of participants based on their expertise, however, the interviewer can ask for more details and change the order of the question according to the discussion's flow. The questionnaire used is self-administrated (i.e., no need for the researcher's presence) and consists of open and closed questions using Microsoft Forms software.

3) SAMPLE FRAME

To choose the proper research sample that meets the research requirements, we need first to determine the research sample frame. Determining the research sample frame is a vital step in conducting qualitative research. The research sample frame is the population from which the research sample is chosen. This research investigated the cybersecurity risk management and evaluation of HIoT BC-IdM systems. The research sample frame in our study is the experts in all fields related to the research problem (i.e., BC, IdM, HIoT security, and cybersecurity risk management experts). The identified research sample is a collection of thirteen experts divided into four categories: Blockchain technology experts (3 interviewees), IdM system experts (3 interviewees), HIoT security experts (3 interviewees), and cybersecurity risk management experts (4 interviewees).

4) SAMPLING TECHNIQUE

After determining the sample frame, we used two non-probability sampling techniques: snowball sampling, starting with a close connection of the supervisors and the researcher, and self-selection sampling by advertising our interest in our topic for a specific sample according to their expertise, using emails from publications, LinkedIn and Research Gate accounts. The experts who were chosen to be contacted met the requirements needed for relevant regulatory, practical, and scientific expertise. When an expert is nominated, his/her profile is checked to ensure having the needed expertise and then contacted. While using the snowball sampling technique produced seven experts, six experts were identified using self-selecting sampling, resulting in thirteen experts. Appendix A shows the experts' years of expertise and qualifications.

5) SAMPLING SIZE AND RESPONSE RATE

In our Delphi study, there was a need to interview experts with specific expertise from specific fields (not random participants). Thus, a non-probability research sample is used in this research. According to [29], a non-probability research sample is used when the sample frame is designated (e.g., experts in a particular field). The right number of samples in such studies is not agreed upon. However, review studies identified that the sample size depends on the nature of

the research. Some unique research problems mandate that the research sample is low. According to [29], the research sample should be ten samples or more, and 12 samples is the minimum sample size to reach saturation. Another recent review study [30] conducted on the size of the research sample in qualitative studies suggested a range between 9-17 as adequate to reach saturation according to empirical tests they studied. In this study, thirteen experts were designated and interviewed in the First Round, and then eleven participants out of them completed an online questionnaire in the Second Round. As Delphi methodology was used in this study, using the same research sample was needed in the two Rounds.

B. INTERVIEWS AND QUESTIONNAIRE PLAN AND DESIGN

The following recommendations by [31] were followed to design systematic interview questions:

- The interview questions should be aligned with the research questions.
- writing inquiry-based conversation questions where questions are written in a less formal way than the research questions.
- getting feedback on the questions.
- to conduct a pilot study.

The interview questions were pre-tested and assessed by one academic and one PhD researcher(not involved in this research project) as a pilot study of the interview questions. We shared the research information sheet and privacy notice with the participants and undertook the interviews using Microsoft Teams. The Second Round was conducted using the Microsoft Forms questionnaire.

C. RESEARCH ETHICS

Ethical approval was granted by the Faculty of Science & Engineering Research Ethics Committee at the University of Limerick, Ireland. Personal data collected for this research project are pseudonymized within two weeks after collection and will be fully anonymized within 12 months. Recordings were used, and after data was transcribed, recordings were destroyed.

D. DATA ANALYSIS

In this study, we used both qualitative and quantitative data analysis. Qualitative analysis is done after conducting the interview. Data is scripted, synthesized based on the panel type, and analyzed and classified by combining similar views with each other and again presenting them to experts in the Second Round using the questionnaire (Questionnaire 1), seeking an agreement about the framework components and evaluation factors. On the other hand, as we used SMART as an MCDM technique, there was a need to use quantitative analysis, in which we used the following formula to calculate the Factor Global Weight (FGW) for every identified evaluation factor: $FGW = FWA/TFWA*100$.

E. DELPHI

Delphi is a method that has been proven to be useful in the information system domain. According to [27], the Delphi method should include five characteristics as follows:

- 1) Use of experts: The study relies on participants who have a wide range of expertise in different topics related to the problem under study. The panel in this study consists of four groups and every group of experts specializes in one specific domain- BC, IdM, HIoT, and the cybersecurity risk management process. In addition, all of the experts have a wide range of expertise in cybersecurity in general.
- 2) Panel: Delphi studies should include a group of experts. Although the number of experts is not limited, it is recommended to keep the number of experts to 10 or more. In our study, we targeted 3 experts from each expertise domain and finalized with thirteen experts when saturation was reached [29]. The experts were divided into four panels according to the expertise domain. Appendix A shows the expert details.
- 3) Rounds: Two rounds at a minimum must be included in Delphi to attain a consensus about an issue. As shown in Figure 2, in this study, the First Round was conducted via individual interviews, and the second one was conducted via a questionnaire. Agreement on the components of the main phases of the cybersecurity risk management process and evaluation factors were sought in the Second Round. In the First Round, the developed framework (version 2), an explanatory introduction about the research problem, and semi-structured open questions depending on the experts' experience were given. They covered the main phase components (including BC and IdM alternatives) and evaluation factors. Following this, the framework was modified to create version 3. In the Second Round, framework version 3 was presented to the experts via questionnaires. The questionnaire includes questions about the framework version 3, and details of every step in the main phases, including the unified evaluation factors. In addition, experts were asked to assign weights to the combined evaluation factors. The interview questions and the questionnaire content from the First and Second Rounds can be accessed in [32].
- 4) Feedback: Feedback must be collected from experts about the research issue and justification should be given. In the First Round of this study, we collected feedback by asking every panel the same group of questions according to their expertise, while in the Second Round, the same questionnaire was distributed to all participants. For example, BC experts were asked about the BC-IdM system human and IT entities' identification. Initially, it was added as a step in the assessment phase in Framework version 2, according to the literature. However, the experts suggested that

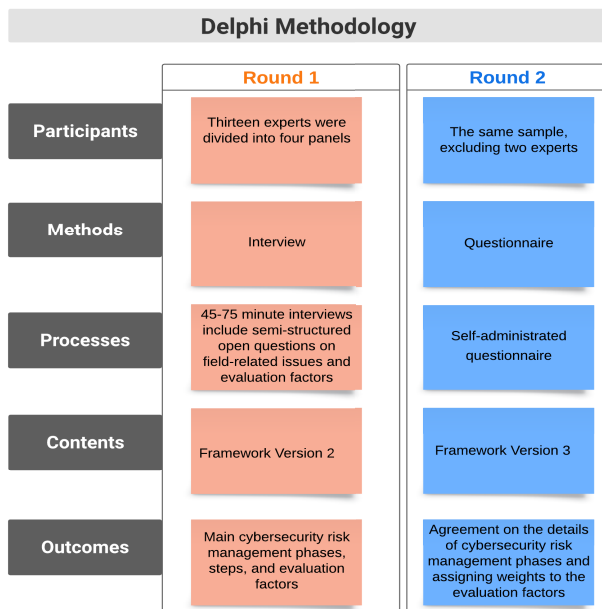


FIGURE 2. Research methodology rounds.

it should be part of the preparation phase and that other steps of the preparation phase, such as standards and requirements identification, should be applied to these entities. Moreover, the regulatory body was added by the experts as a human entity, while it was not considered in the literature. Therefore, it was added in version 3. In the Second Round, the experts were asked about the list of the entities, including the inclusion of the regulatory body, and all agreed that it should be added. Thus, it is included in the final version of the framework as it is an integral part of the cybersecurity risk management process.

- 5) Anonymity: Anonymity is vital in Delphi studies. It allows participants to give their opinions without fear of the position's impact. It is guaranteed in this study by applying ethical approval number "2023-02-05- S and E", which was granted by the Faculty of Science and Engineering Research Ethics Committee at the University of Limerick. It mandates that the collected personal data be pseudonymized within two weeks after collection and anonymized within 12 months.

F. SMART

SMART is one of the MCDM techniques. MCDM techniques are widely used to support decision-makers/ experts to evaluate and better select IT solutions. According to [33], MCDM weighting methods are used in different fields, such as risk management, engineering, and science technology. It is an integral part of research that includes an evaluation process to identify factors. They can be divided primarily into subjective methods, where experts assign weights to factors, or objective methods, where expert preference is not

considered in the weight-assigning process. The subjective methods are divided into direct weighting methods and pairwise comparison methods. In [3], we summarized the MCDM weighting methods used in the previous BC-IdM evaluation studies. SMART is a subjective direct weighting method used in this study for its simplicity in interviewing experts [34] and as it fits the purpose of our study. It is used widely to allow experts to assign from 10 to 100 points to factors directly, where 10 represents the least important factors and 100 is the most important. For example, in [35], researchers used SMART to select BC platforms for enterprise systems. Evaluation factors were initially identified in our previous work [3]. After that, the interviewed experts were asked in the First Round of interviews to add factors according to their experience. In the Second Round, the experts were presented with the combined and synthesized factors, in which they assigned importance weights to the evaluation factors that should be used to evaluate HIoT BC-IdM systems, following the SMART technique. In SMART, there are four steps need to be fulfilled, 1) alternative options identification, which are the BC-IdM solutions in this study, 2) evaluation criteria identification, which are the BC-IdM evaluation factors, 3) giving values for every criterion and calculating the total and combined values, which is the purpose of using SMART in this study, and 4) choosing the best solution based on the values. The first three steps were conducted as follows:

- Identifying BC-IdM solution alternatives, i.e., BC and BC-IdM models and tools from the literature review and evaluated by experts. The details of the existing BC-IdM solutions that are most commonly used are available in Appendices B, C, and D.
- Identifying evaluation factors, initially identified in previous work [3] and evaluated by experts in this study.
- Assigning weights to the evaluation factors following SMART using a questionnaire. Eleven experts were involved in this process. After values were assigned by every expert, using Excel Microsoft, the following formula was used to calculate the Factor Global Weight (FGW) for every factor: $FGW = FWA / TFWA * 100$, Where FWA is the Factor Weight Average, and TFWA is the Total of Factor Weight Average. For example, Integrity $FGW = 96.636 / 2229.182 * 100 = 4.335$ percent. The FGW represents every factor's value out of the Total FGW, i.e., 100 percent. The FGW for all twenty-six evaluation factors was calculated following this formula. Details of the assigned weights can be accessed at [32].
- While the first three steps were conducted in this study, the fourth step is to be done by the decision-makers. They can use the total of FGW to evaluate the robustness of solutions they are developing and select the most suitable solution that meets their needs.

V. RESULTS

In this section, outcomes based on the Delphi method rounds are summarized, as follows:

A. OUTCOME OF FIRST ROUND

Thirteen experts were asked seven semi-structured open questions concerning the framework's main components and different security aspects of the HIoT BC-IdM system. Questions were chosen according to the experts' domain. Feedback from the First Round played a role in enhancing the framework version 2 by giving general feedback, such as the need to give more details about the framework components and evaluation factors, limiting the scope and context of the framework, clarifying the framework audience, and adding/moving steps from one phase to another. In addition, details of some steps, such as BC-IdM functional requirements identification, were added in the framework version 3, which was presented in the Second Round to the experts, alongside the evaluation factors and domain-related recommendations that are recommended by experts from different panels. The feedback from the following panels fed into the Second Round questions' content and resulted in the framework explained in the following section. The main synthesized themes of the responses can be categorized based on the four researcher domains as follows:

1) BLOCKCHAIN EXPERTS

Three Blockchain experts were involved in this panel. The questions revolved around the BC platforms that better fit HIoT IdM systems security and functionality, the cybersecurity risks aspects related to the developed framework, and the evaluation factors. In terms of security, they agreed on the importance of the CIA (confidentiality, Integrity, and Availability) triad, Authentication, and Privacy requirements in the BC technology. In addition, they emphasized the business nature and regulations of BC applications (financial or general business projects) (regulated or not). Appendix B shows the details of identified suitable BC platforms for industry [35], [36], from the interviews and our previous works [1], [2], [3]. Although the literature produced a list of BC technologies, which can be used in the comparison process between the alternatives of BC-IdM technologies, experts recommended new BC technologies, which showed promising capabilities in the applications of BC-IdM systems, such as Quorum and Corda BCs. They were added in the final version of the framework. In addition to identified evaluation factors, such as scalability, BC experts gave more importance to the availability of regulated BC technologies, and BC support community, such as Hyperledger Foundation, and factors like cost.

2) IdM SYSTEM EXPERTS

Three IdM experts were interviewed in the First Round. The questions given to this group revolve around IdM systems security and functional considerations, including BC-based IdM systems, cybersecurity risk aspects about the HIoT IdM systems, and evaluation factors that must be considered when planning to upgrade or change from one IdM model to another. Experts emphasized the foundational

and functional requirements that BC-IdM should support. They recommended identifying these requirements in detail in the framework. Also, they gave importance to the evaluation factors in relation to BC-IdM, governance, functional requirements, and principles. Experts gave the evaluation aspect of the BC-IdM importance and declared a lack of such aspect in the existing time. They also emphasized preparing backup and recovery plans for such new IdM systems. Appendices C and D show the IdM models [3] and a comparison to the most promising BC-IdM tools [22].

3) HIOT SECURITY EXPERTS

Three HIoT and medical device experts were among the interviewees in this panel. The questions they were asked focus on 1) the current HIoT IdM system security issues, such as HIoT identification, regulations, and impacted stakeholders, 2) the suitability and needs of new decentralized BC-IdM systems, and 3) the evaluation factors and considerations that must be considered when planning to adopt such systems and build a cybersecurity framework. Experts emphasized the security issues that are special to HIoT systems. The authentication, identification, and ownership issues that still exist in classical IdM systems in HIoT, health-related regulations, such as the Health Insurance Portability and Accountability Act (HIPAA), and standards that must be considered when using BC-IdM systems in HIoT, such as Fast Healthcare Interoperability Resources/ Health Level Seven (FHIR/HL7). They also highlighted the need to update health privacy regulations to keep up with BC applications. Also, some impacted stakeholders other than those identified in the literature were identified by this panel, such as medical insurance companies, by which their reputation gets impacted when the HIoT user privacy is breached. Moreover, the user acceptance of such systems was highlighted again in this panel.

4) CYBERSECURITY RISK MANAGEMENT EXPERTS

The last panel of interviewed experts included four cybersecurity risk management experts. The questions in this group were around the cybersecurity risk management process for security solutions (i.e., IdM systems) using emerging technologies (i.e., BC), which are planned to be used in complex and sensitive systems, such as HIoT. As cybersecurity experts, the experts were insightful of the development of cybersecurity risk management frameworks and aware of the trend of using BC for security solutions in different domains. They ensured that the developed framework aligned with international standards, such as NIST 800-39 and ISO 27005, and entailed all needed steps. They emphasized the importance of the evaluation part of the framework. They highlighted the need to include precise security and privacy controls, mitigations, and countermeasures classified clearly according to the system assets and related threats. Moreover, experts shed light on the need to include a clear scope, context, and audience of the framework.

B. OUTCOME OF SECOND ROUND

A questionnaire was distributed to the same group of experts who consented in the First Round to participate in the questionnaire (for unforeseen circumstances, two experts did not respond to the questionnaire in this round). The questionnaire consists of three sections, which include closed and open questions: 1) The first section focused on the evaluation factors, where the combined evaluation factors were listed. Previously, factors were listed by the researcher and presented to the panels to add theirs. All experts agreed with the research list. Therefore, the list was presented again in the Second Round, and weights were assigned, 2) The second section focused on the details of the cybersecurity risk management process. The framework steps details, such as the team members, system entities, standards, and other details, were presented in individual questions, and experts were asked to give their feedback on the details, either by agreeing with the content or giving recommendations. All recommendations were considered in the final version of the framework, such as adding details of the security polices, which as a result, were added from the studies previously reviewed, 3) and the third section, which involved general questions about the evaluation and cybersecurity risk management framework. In this round, feedback from the first section of the questionnaire contributed to assigning weights to the evaluation factors. While Feedback from the second and third sections was used to improve the framework content in general. The questionnaire content and the participants' assigned weights are available in [32]. Findings from this round are summarized based on the outcomes and changes in the framework as follows:

1) EVALUATION FACTORS IDENTIFICATION AND ASSIGNING WEIGHTS

Experts were asked to rank the factors from least to most important and assign between 10 - 100 points to them, following the SMART technique guidelines. After assigning the values by experts. The FGW and total FGW were calculated as shown in Table 5. Table 5 shows the identified factors with FGW values in descending order according to the factor importance. The details of the factors are explained in the following section.

Even though all factors are considered important, it is clear from the rankings that are derived from experts' assigned values that the security and privacy evaluation factors (Availability, confidentiality, Integrity, Authentication, and privacy) scored the most important factors. The regulations factor, which is part of the external evaluation factors recorded as the most important factor after the security and privacy factors.

2) FRAMEWORK CONTENT-RELATED FEEDBACK

The main and secondary steps of the framework and details of the framework were presented to the participants, and feedback was sought. Details included the needed team members

to conduct the evaluation and assessment process, system entities and assets, standards, HIoT BC-IdM requirements, principles, controls, policies, threats, attacks, vulnerabilities, impacts classifications, potential risks, and countermeasures. We identified a number of 103 security and privacy controls divided according to main assets and their secondary assets: HIoT application (53 controls), BC (19 controls), and BC-IdM systems (31). Also, 41 threats, 23 vulnerabilities, and 39 countermeasures were identified. Moreover, thirteen BC platforms that can be used to develop decentralized IdM systems were identified from the literature review and interviews. Details about these components are presented in the following section. In the third section, experts were asked general questions. Questions in this section include questions about the comparison process content and the audience of the framework. Also, they were asked if they had other general recommendations to improve the framework.

TABLE 5. Global evaluation factor weights.

Evaluation Factor	FGW
1. Availability	4.428 %
2. Confidentiality	4.416 %
3. Authentication	4.343 %
4. Integrity	4.335 %
5. Privacy	4.302 %
6. Regulations	4.196 %
7. Governance and compliance	4.188 %
8. Performance	4.135 %
9. HIoT regulations	4.090 %
10. HIoT standardization	4.082 %
11. IdM functional requirements	3.976 %
12. Interoperability	3.878 %
13. Recovery plan	3.861 %
14. Awareness	3.784 %
15. End-user friendliness	3.768 %
16. Safety	3.755 %
17. Resilience	3.731 %
18. Sustainability	3.694 %
19. Scalability	3.633 %
20. Solution acceptance	3.633 %
21. HIoT-related considerations	3.572 %
22. Cost	3.519 %
23. BC-IdM principles	3.417 %
24. BC support community	3.209 %
25. Agility	3.172 %
26. Suitability	2.871 %
Total FGW	100 %

VI. THE DEVELOPED FRAMEWORK

The framework explained in this section is an outcome of a consolidation process of the findings from our previous works and a systematic evaluation process conducted in this

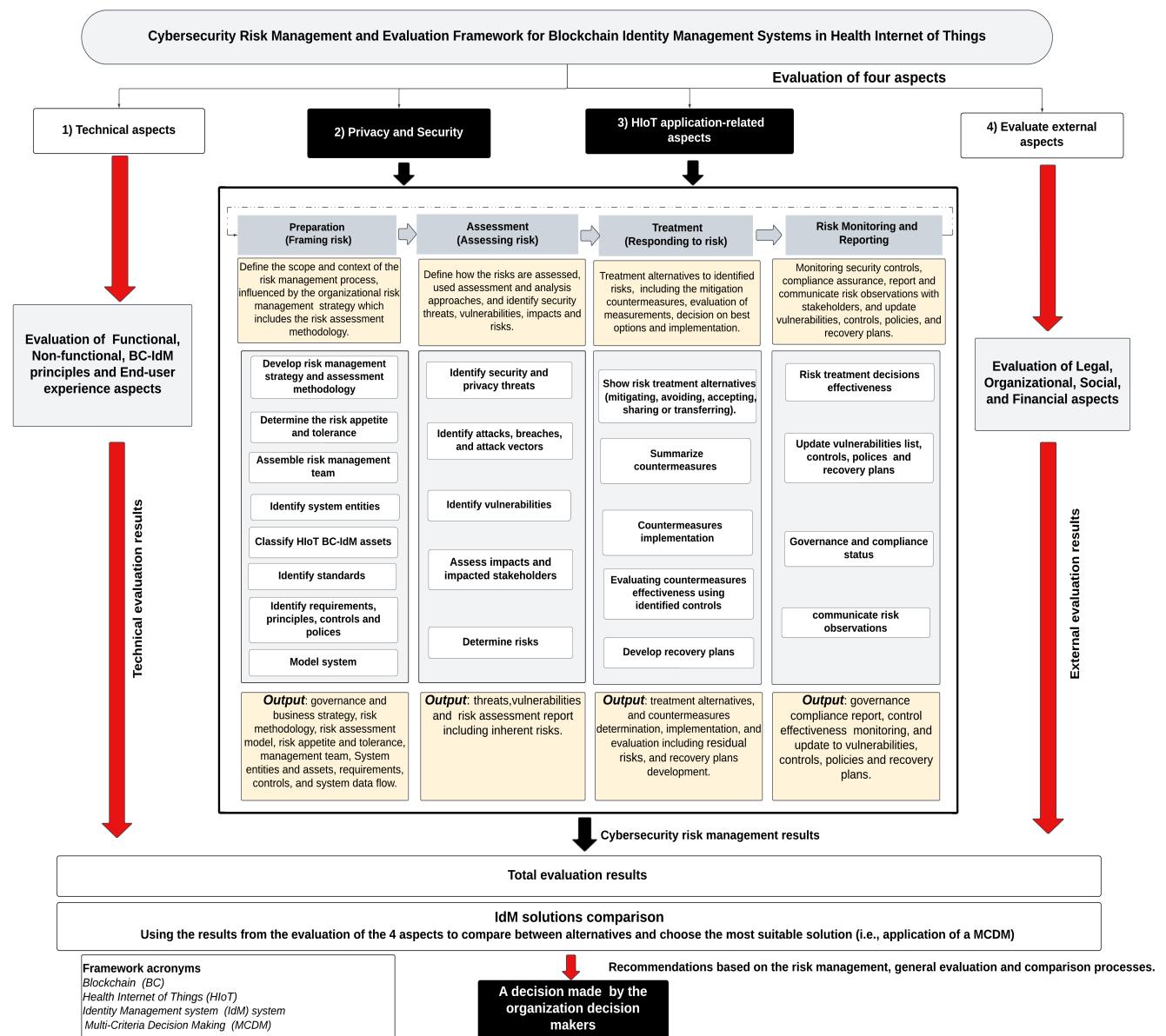


FIGURE 3. Cybersecurity risk management and evaluation framework.

work using the Delphi method by employing feedback from specialized experts.

The evaluation and Cybersecurity Risks Management Framework in this article focuses on the cybersecurity risk management process at the information system level of healthcare organizations that incorporate BC-IdM for HIoT systems. It also intends to help leaders/ cybersecurity individuals in these organizations evaluate the whole BC-IdM system and manage cybersecurity risks. It can help to manage cybersecurity risks, comply with the regulations and standards, and support IT solution initiatives, which will save unneeded financial costs. Figure 3 shows the developed cybersecurity risk management and evaluation framework, which can be used as a guide by the following intended

audience with the subsequent associated texts that explain all phases and processes in the cybersecurity risk management and evaluation framework.

- Health organization leaders responsible for overseeing the risk management process.
- Managers in charge of conducting business missions, such as business owners.
- Individuals in charge of upgrading and acquiring new systems in healthcare organizations.
- Development and implementation teams, such as enterprise architects, information security architects, information security engineers, and program managers.
- Security managers in charge of overseeing information security in healthcare organizations, such as

information security officers and information system owners.

- Technical security teams in charge of risk assessment/analysis and security monitoring tasks.

Whilst all the above-mentioned should be familiar with the risk assessment, there will be different levels of engagement in using the framework. While health organization leaders only require a high level of interaction and understanding, others need a more detailed understanding of the evaluation and risk management processes details when applying it.

As shown in figure 3, the framework includes two main processes, i.e., the evaluation of the four aspects and the cybersecurity risk management processes. The results from the total evaluation and the IdM solutions comparison lead to the decision regarding the suitability of using such solutions. The detail of the framework is explained in the following subsections.

A. EVALUATION PROCESS

It is fundamental to evaluate the entire HIoT BC-IdM ecosystem to ensure the development of a reliable system. The evaluation process should relate the BC-IdM solution to the HIoT ecosystem and should include security, privacy, technical, HIoT-related, and external factors. Doing this allows the decision-makers to be aware of the whole picture of the BC-IdM system developed for HIoT. Overall evaluation of the HIoT BC-IdM system is a main part of the developed framework. The evaluation process in this framework consists of four aspects:

- Technical aspects evaluation.
- Privacy and security aspects evaluation.
- HIoT-related aspects evaluation.
- External aspects evaluation.

In this study, we cover the second and third aspects of the cybersecurity risk management process (i.e., privacy and security and HIoT-related aspects) in detail. However, the detailed evaluation of the technical and external aspects are considered open research issues. The final list of twenty-six identified evaluation factors covers all four aspects.

1) SECURITY AND PRIVACY FACTORS

- Integrity: The integrity of data is a critical and fundamental security factor, which has an ultimate effect on the safety of HIoT users.
- Confidentiality: In dealing with health data, there is a need to deal with data with higher security because of the sensitivity of data, that to ensure data is confidential. This factor is fundamental for the security of HIoT BC-IdM.
- Availability: Availability of the data and system services, especially when continuous observation is needed for system users, such as patients. It is at the core of the evaluation of HIoT BC-IdM system security.
- Authentication: Authentication of the HIoT user/patient is critical in IdM systems to guarantee that whoever is using the HIoT is the right user, and if it is not

considered, it might lead to severe consequences when data is interrupted.

- Privacy: Privacy is vital for BC-IdM dealing with health data. Privacy mechanisms ensuring user consent (privacy by design) and other data subject rights that are preserved by the General Data Protection Regulations (GDPR) are fundamental. The implications of patient data leakage are critical. If HIoT used by patients gets hacked because of a non-GDPR-compliant BC-IdM system, this might lead to vital privacy breaches.
- Recovery plan: The data owner/ HIoT user is the masterpiece in the BC-IdM system; thus, the backup recovery plan in the case of failures, such as when the data owner deletes data deliberately or mistakenly, is essential to sustain the service of the system.

2) TECHNICAL FACTORS

- Performance: Performance evaluation is essential to evaluate BC-based systems. It can be evaluated using the identified performance criteria. Criteria and sub-criteria used to evaluate performance are: transaction throughput and size, block size, chain size, latency, network size, the volume of P2P traffic, traffic structure, propagating transaction rate, contract execution time, packet loss ratio, node CPU, memory, storage, and connectivity, read latency, read throughput, cache hit ratio, communication cost, computation cost (ms), storage overhead (Bits), BC storage size, BC update time overhead (ms), the impact of BC consensus rate, and transaction generation time (ms).
- IdM Functional Requirements: Factors related to technology, implementation, and operations of BC-IdM main functions, i.e., in relation to the enrollment and proofing process, the authentication and lifecycle management process, and federation between Relying Parties (RPs). The system can not function and provide the required services if these functional requirements are not considered.
- Scalability: Scalability is an essential evaluation factor in HIoT BC-IdM. When entities authenticate each other, this process increases the system's management load. In some scenarios in HIoT BC-IdM, the device authenticates the doctor or user with other points (i.e., sensors and doctors in a hospital), which leads to the need for a high-level management system. This results in energy consumption, which makes the device battery die quickly, and as a result, reduces the energy efficiency. The increased number of BC-IdM users will decrease the system's efficiency. This can be solved by using off-chain storage; however, this leads to other issues related to the cryptographic algorithms used to match metadata in off-chain storage and BC storage. The algorithms used in BC-IdM systems should be suitable to support HIoT scalability. Thus, there should be a trade-off between security and scalability.

- **Sustainability:** BC applications are evolving, thus, selecting a sustainable system is important. Using sustainable BC infrastructures and open-source standards is substantial to keep up with BC's constant development.
- **Interoperability:** Interoperability is one of the BC-IdM promising features, thus, it should be evaluated against this feature. In addition, IdM systems in HIoT should consider the need for managing and exchanging data with multiple stakeholders and system users.
- **Suitability:** Suitability of BC-IdM solutions to domains is an important factor. Not all BC technologies are suitable for IdM systems with a high number of entities, such as HIoT. There must be added value to the user and organization, which weighs the classical IdMs.
- **Safety:** Safety is an evaluation factor that should be considered in healthcare systems. HIoT users' (e.g., patients) safety can be affected by hacking, breaching, or tampering with their data. Safety is always an essential evaluation factor in healthcare systems.
- **Agility:** The ability to change for future needs is another factor to keep up with the BC evolution. It is especially important in BC paradigms.
- **BC Support Community:** It is essential to rely on BC infrastructures that have a reliable community to support the development of BC-IdM applications. World Wide Web Consortium (W3C) and, Decentralized Identity Foundation (DIF), Hyperledger Foundation are examples of support communities to BC technologies.
- **Resilience:** Resilience is an important technical measurement factor that depicts system survivability. Similar to sustainability and Agility, there are evaluation factors that are essential for the changing nature of BC technologies and infrastructures.
- **BC-IdM Principles:** BC-IdM systems should be built based on quality and functional principles that are compliant with laws, regulations, and standards. Twenty principles were identified that should be considered in developing BC-IdM systems.
- **End-user Experience:** To what extent users can use the BC-IdM solution to achieve aimed goals with efficiency, effectiveness, and satisfaction in the HIoT context is essential to the solution being accepted.

3) APPLICATION-RELATED FACTORS

- **HIoT-related Regulations:** This factor is used to ensure compliance with health regulations such as HIPAA. Compliance with such special regulations should be considered in developed BC-IdM systems.
- **HIoT Technical Standardization:** Application standardization factors that assess compliance with the application-related standards, such as FHIR/HL7 health data exchange protocol and HIPAA. Without considering this factor, the HIoT-related security and effectiveness are defective.
- **HIoT Considerations and Requirements:** HIoT constraints and requirements where the BC-IdM system is

proposed are factors that play an important role in evaluating the effectiveness of the BC-IdM systems proposed. For example, storage and identification constraints in the HIoT systems lead to storing health data outside the healthcare settings, i.e., in the cloud. Also, requirements concerning the suitable BC network (i.e., private/public) should be evaluated when developing BC-IdM systems. For example, only permissioned BC type should be used for healthcare systems [37]. Thus, considering HIoT requirements and constraints should be evaluated.

4) EXTERNAL FACTORS

- **Regulations:** Regulations are a key factor in BC-IdM systems in HIoT. At the current time, regulations related to BC-IdM are general, and there are no health data-focused regulations. The more regulations are specific, the more secure and privacy-preserved can be achieved. This is applicable to HIoT, health data, and BC applications as BC-IdM systems. Using regulated BC technologies is essential to build a reliable BC-IdM system in HIoT.
- **Governance and Compliance:** Whether the HIoT BC-IdM supports regulated governance and can be compliant with regulations is an essential factor. Governance can be divided into three subsections: 1) overall governance regarding the use of BC in such organizations acquired from national GDPR 2) technical governance, which is related to the implementations of the BC-IdM systems, i.e., BC-IdM system governance. For example, the ID issuer should have an agreement with the ID owner to clarify responsibilities. This type should be derived from the overall governance, and 3) HIoT application governance concerning health data-related regulations, i.e., HIoT system compliance with health regulations such as FHIR/HL7 and HIPAA [38].
- **Solution Acceptance:** User acceptance of the solution is a factor that should be evaluated. Studies on the acceptance of HIoT BC-IdM systems on users such as patients and health settings staff should be conducted to ensure applicability and identify concerns in order to eliminate them.
- **Cost:** Cost of BC-IdM services is an essential factor, by which the user/ organization calculates the added value and compares it with other available BC-IdM/ IdM systems. Some public BC platforms, such as Ethereum, mandate cost for the service, which might lead to a decrease in its applicability and usability in HIoT BC-IdM systems.
- **Awareness:** In BC-IdM there are four main elements: Identity provider, owner, verifier, and BC as infrastructure. User responsibility is higher in BC-IdM systems. The identity owner, such as the HIoT user, has the burden of control responsibility on their IDs, from specifying what data can be shared to revoking their access and ID. Elevating the user's knowledge and awareness is essential to be able to function the system. Moreover,

when adopting BC technologies in organizations, not only users should be educated, but also organizations' system owners/administrators need to be educated on how to run the system.

B. CYBERSECURITY RISK MANAGEMENT PROCESS

1) FRAMING PHASE (PREPARATION PHASE)

The purpose of this phase is to specify the risk context. Framework context is an essential part of every cybersecurity risk management (CRM) process [39]. The context of this framework is healthcare organizations that plan to use BC-based IdM systems for HIoT systems. The scope of the cybersecurity risk management process is the whole HIoT BC-IdM system, including the whole data flow in relation to HIoT device security, data security, and user privacy. It is recommended to start the risk management process with a framing phase that identifies the sources of needed information, individual responsibilities, assumptions, and constraints, which include the system environment operational analysis, security domains, boundaries, and data flow scenarios. One of the main outputs from this phase is the risk management strategy which shows the risk tolerance and appetite, constraints, and methodologies to be used in the risk assessment phase. It should explicitly specify how the health organization assesses, responds, and monitors the identified risks. The risk assessment methodology is determined in the risk management strategy. It includes a description of the risk assessment process, risk assessment model, and risk assessment and analysis approaches. We identified the risk assessment process, risk assessment model, assessment, and analysis approaches for HIoT BC-IdM cybersecurity risk management process as follows:

- The risk assessment process includes the main processes involved in risk assessment, i.e., threat identification, vulnerability identification, impact, and risk determination.
- The Risk assessment model includes the key risk factors and the relationships between them. It includes 1) Assets such as Users, HIoT applications, BC, Off-chain, connectivity, and HIoT device assets, 2) Requirements, 3) threats, 4) vulnerabilities, 5) attacks, 6) controls, and 7) countermeasures. The key risk factors and the relationship between them were identified and explained in our previous work [1].

In addition, security risks in IdM systems are triggered by contributing security risk factors, which must be considered in IdM systems that use tokens in identification, authentication, and authorization processes, which according to [40] and [41], can be used in IdM security and privacy assessment model. Token-based IdM system contributing risk factors include Token Mobility, Token Value at Risk, Token Provisioning, Token Frequency and duration of Use, Token Use and purpose, Token Assignment and relationship, Token Obligation and policy, Token Claim Type, Token Secrecy, and Token Security.

TABLE 6. The cybersecurity risk management team members.

Team member	Expertise needed/ Input sought (justification)
Executive manager in the healthcare organization/ Product manager/ Project manager	Defining the process scope, security and privacy risk tolerance, and residual risks
HIoT user	user experience and concerns
Risk assessor	Risk analysis and assessment
Third-party resources, i.e., BC-IdM service providers	Development, Consultant, penetration
IdM and BC expert	IdM system upgrade requirements and BC capabilities.
Software/Hardware/Network specialists	Members to ensure a full understanding of underlying technologies.
Data protection officer	Data protection laws compliance

- Risk assessment approaches [39]: qualitative, quantitative, and mixed approaches can be used to assess risks in information systems or organizations. The selection is based on the organization's culture and influenced by factors, such as cost and risk uncertainty. While quantitative approaches use numerical values to assess risk, qualitative use non-numerical values (i.e., very high, high, moderate, low, very low). In mixed approaches, both numerical and nonnumerical values are used to assess risk and risk contributing factors (i.e., numerical scales (e.g.,1-10) are interpreted into nonnumerical values).
- Risk analysis approaches [39]: risk analysis approaches are classified into threat-based, assets-based, and vulnerability-based. Although the order of risk assessment activities and factors can be used differently, all approaches should use the same risk assessment activities and factors. The selection of risk analysis approaches is flexible and can be based on the availability of information.

a: RISK TOLERANCE AND APPETITE

Risk tolerance is defined as the level of risk an organization accepts. The risk tolerance statement should be written according to the risk management strategy. It gives consistency in dealing with risks. Based on the risk tolerance, the identified risks are dealt with accordingly. Risk tolerance determination is based on the organization's strategic objectives and can be calculated using the risk appetite statement, which is a more general statement concerning the risk acceptance level [38].

b: TEAM ASSEMBLING

Assembling a team to conduct the cybersecurity risk management process is essential [42], [43], [44], the team should include internal and external members, as shown in Table 6.

c: HIoT BC-IdM SYSTEM ASSETS AND ENTITIES

Studying the cybersecurity of BC-based information systems such as HIoT BC-IdM should consider two types of entities,

human and IT (socio-technical perspective), in which the security attacks occur because of the relationship between these entities. HIoT BC-IdM entities can be classified as follows [45]:

- **BC Infrastructure:** The used BC technology, e.g., the BC listed in Appendix B. BC infrastructure vendors come under this entity.
- **BC Application:** In our case, it is the BC-IdM system built using BC technologies for HIoT.
- **HIoT System:** the targeted system where the BC-IdM system is used. The HIoT systems requirements and considerations can be exploited by attackers if developers do not consider them.
- **Users:** In our case, the IdM owner, issuers, and verifiers use the BC-IdM and can impact its security and privacy with misuses.
- **Developers:** They use BC to build applications on top of them. Missing security properties by developers impacts the security of such systems.
- **Attackers:** They are adversaries that exploit the weaknesses of the former four entities in order to conduct malicious activities.
- In addition, the regulatory body is an integral entity in the HIoT BC-IdM system, as it plays a role in regulating the BC-IdM solutions.

Every cybersecurity risk management process should consider these entities. Figure 4 illustrates the cybersecurity risk entities in HIoT BC-IdM systems and the relationship between them.

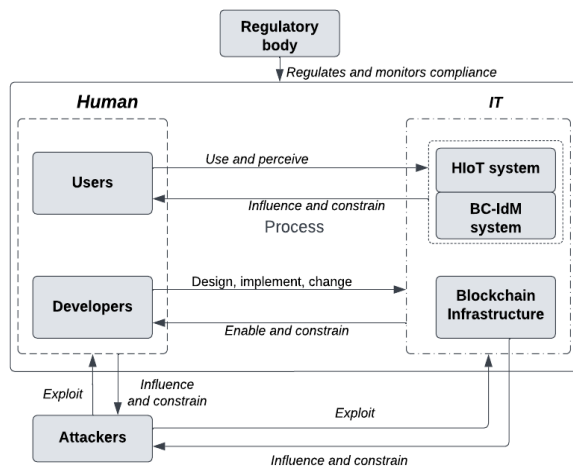


FIGURE 4. Cybersecurity risk entities in HIoT BC-IdM systems.

Identification of the HIoT BC-IdM asset is an essential activity to limit the scope of the CRM process. The assets' criticality level is vital to developing countermeasures, recovery plans and treating security risks. It gives priority to dealing with the most critical assets, which should be aligned with the organization's strategy. The whole HIoT data life cycle assets should be assessed. Three main IT assets were identified in the HIoT BC-IdM systems, which

should be included in every HIoT BC-IdM scenario: the HIoT application, BC technologies, and the IdM system. Also, secondary assets, such as systems and mechanisms that are used to ensure IdM processes (such as enrolment, authentication, and validation), cloud interfaces where data flow through should be considered, and mobile devices where the ID owner stores their IDs. More details of the main/ secondary assets are in the data flow sub-section and Appendix E.

d: HIoT BC-IdM STANDARDS

Specific applications and organizations should follow specific standards. Identifying related standards are essential for the cybersecurity risk management of information systems. Using state-of-the-art technology to solve security issues is important; however, with emerging technologies such as BC, many risks are yet to be known, so the new product should be standardized. Thus, following organizations' standards and regulations like NIST, ISO, and GDPR is essential. Several studies apply general cybersecurity risk management standards were identified and summarized in our previous work [1], and validated by experts in this work. They can be divided into four categories: 1) general cybersecurity risks management and information security standards, 2) digital identity risk management standards, 3) HIoT cybersecurity risks standards, and 4) BC technology security standards. Appendix F shows the details of the standards. Some of the standards that our study considered in developing our framework are as follows:

- NIST 800-37: Risk Management Framework for Information Systems and Organizations A System Life Cycle Approach for Security and Privacy [46].
- NIST 800-30, Guide for Conducting Risk Assessments [39].
- NIST 800-63-3 Digital Identity Guidelines [47].
- NIST 800-39: Managing Information Security Risk: Organization, Mission, and Information System View [38].
- NIST 800-53, Recommended Security Controls for Federal Information Systems and Organizations [48].

While the main structure and content of this cybersecurity risk management framework were acquired from the first category of standards, the digital identity management standards are used to show the main functional components of IdM, which help in the IdM system assurance [47]. As our framework targets BC-IdM for HIoT, we needed to survey and review standards released by reliable standards avenues such as the National Institute of Standards and Technology (NIST), the International Organization for Standardization (ISO), Food and Drug Administration (FDA), and European Network and Information Security Agency (ENISA), in addition to the academic reviewed studies. Clear visibility of the data flow is important in protecting IdM systems against security risks. IdM systems consist of different accounts, such as IdM accounts, administrator accounts, privileges accounts, and service accounts, which are used to run the IdM

system itself. They all need to be considered when conducting risk management for IdM systems. NIST published special publications 800-63-3 concerning digital identities [47] (i.e., IdM systems) where IdM system risk management is given more concentration. There are considerations in three main functions in order to manage risks in digital identities according to [47]: Identity proofing errors (i.e., a false applicant claiming an identity that is not rightfully theirs), Authentication errors (i.e., a false claimant using a credential that is not rightfully theirs), and Federation errors (i.e., an identity assertion is compromised). There is a lack of focused IoT (including HIoT) IdM cyber security risk management standards. However, we used relevant standards that we identified in our previous work [1], such as [4], [49], and [50]. Specific considerations should be given to HIoT systems as they are highly interconnected with other system components. Thus, three main considerations should be considered:

- IoT systems (including HIoT) impact the physical environments they are used in, which mandates carefully studying the cybersecurity and privacy implications to the whole HIoT ecosystem.
- Access and management to HIoT systems are different from regular IT systems, which mandates expanding the risk management process to cover other systems stakeholders such as software, vendors, and manufacturers. Such third parties would have access to HIoT devices.
- Cybersecurity capabilities, efficiency, and availability in these systems differ from classical IT systems. Thus, additional cybersecurity and privacy controls need to be taken.

Figure 5 shows the capabilities that the IoT systems (including HIoT) that represent the assets in which security and privacy risks might occur. The capabilities entail sensors, applications, human and network interfaces, device management, cybersecurity, and privacy systems.

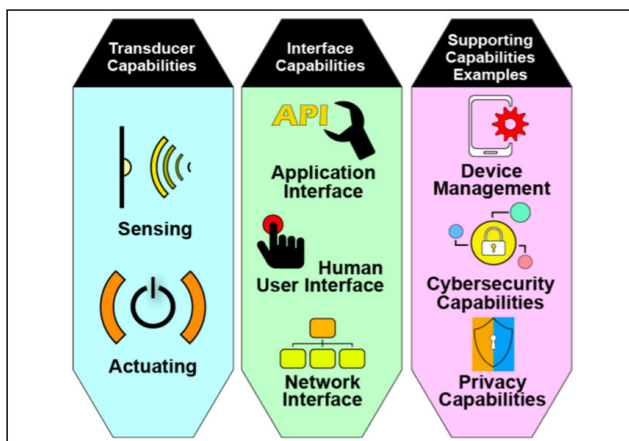


FIGURE 5. HIoT capabilities that cause cybersecurity and privacy Risks [27].

Moreover, according to [49], three risk mitigation goals should be considered in order to manage the cybersecurity

and privacy risk management of HIoT: 1) device security protection, 2) data security protection, and 3) individual privacy protection. Therefore, these three goals are considered in the proposed HIoT BC-IdM cybersecurity risk management framework.

Some BC-related standards, such as [20], [51], [52], and [53], were identified in addition to the reviewed academic studies. Although these standards are almost informative and do not give technical views or detailed best practices, information about BC applications and cybersecurity recommendations from these reports were taken into consideration. For example, in [53], data protection regulations such as GDPR and EU eIDAS are discussed. Recommendations in relation to GDPR data owner rights issues, eIDAS compatibility with BC, and regulatory open issues are given in order to align the BC-IdM systems with the EU data protection regulations and electronic identification standards. In [54] and [55], smart contract-based access control and BC tokenization are discussed. These standards can be used to evaluate the performance of BC-IdM systems.

Moreover, several reviewed studies are found relevant to our framework aim, which relies on general cybersecurity standards considered in the framework as discussed in the assessment phase in the framework.

e: HIoT BC-IdM REQUIREMENTS, PRINCIPLES, CONTROLS, AND POLICIES

1) TECHNICAL, SECURITY, AND PRIVACY REQUIREMENTS

According to [51] and [53] and some of the IdM interviewed experts, as there are no agreed BC-IdM standards (released by organizations such as NIST, ISO, and ENISA) that show the cybersecurity and technical requirements, BC-IdM systems should follow requirements from the available standards of conventional IdM systems. Any IdM system should include three types of assurance to ensure IdM functionality and security: 1) Identity Assurance Level (IAL) in relation to the enrollment and proofing process (verification), 2) Authenticator Assurance Level (AAL) concerning the authentication and lifecycle management process, and 3) Federation Assurance Level (FAL) to ensure communication the authentication process between Relying Parties (RPs). These components are used in the digital identity cybersecurity risk assessment process to mitigate authentication errors. Every one of these three assurance types has three levels with different requirements and capabilities based on the system's needs. Figure 6 shows typical digital identity processes and main components, whereas Figure 7 shows the relation between the main entities in the IdM federated systems [47].

To assure identity proofing (user proofs whoever claims), a Credentials Service Provider (CSP) should at least use attributes such as full name, date of birth, and home address (not national numbers) to prove such identities. There are three sub-processes to accomplish the proofing process; presentation, validation, and verification [56]. IdM systems

should consider general requirements for identity proofing and special requirements for every sub-process. Security and privacy risk considerations should be considered in this process are shown in Table 7.

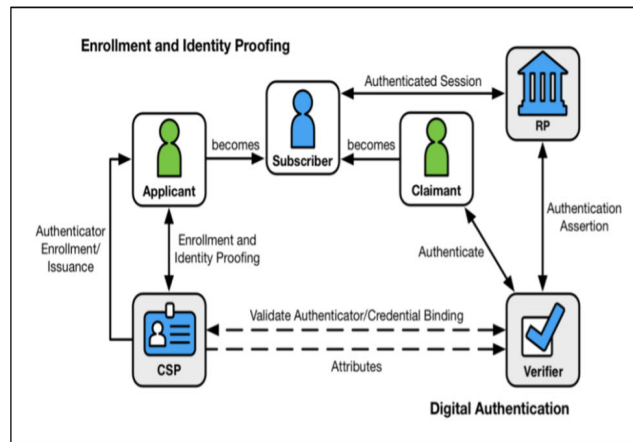


FIGURE 6. Digital identity main functions [25].

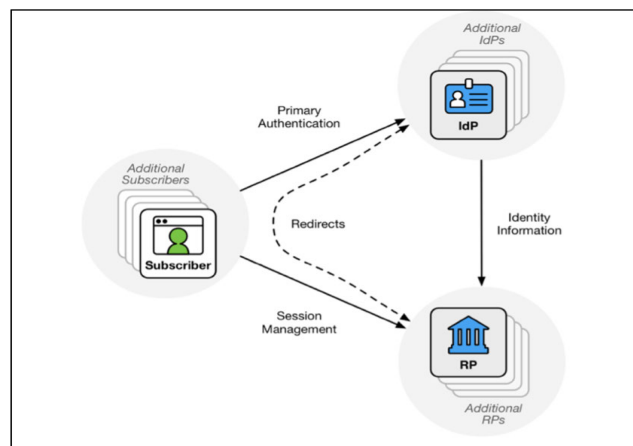


FIGURE 7. Federation function components [27].

Several considerations and requirements should be taken in this process to ensure identity authentication and life cycle management. Several types of authenticators (means used to identify users) can be used in this process, such as memorized secrets, look-up secrets, out-of-band, single-factor, and multi-factor cryptographic software. Authenticators and verifiers are required to follow specific rules to ensure identity authentication. In addition to the requirements mentioned previously, IdM systems shall be compatible with healthcare systems standards such as HL7/FHIR. HL7/FHIR released special requirements for digital identity systems in healthcare systems to support interoperability. It requires at least AAL2 (multi-authentication factors) authentication assurance and should be FHIR-ready, i.e., compatible with FHIR digital identity standards [57].

To ensure AA2 authentication, either one multi-factor authentication mechanism may be used or two single-factor

authentications combined (one is memorized secrets, and one is position-based (something users own)). The communication channel between the authenticator and verifiers (BC in our case) should be authenticated to guarantee confidentiality. In addition, when using smartphones in the authentication process, the phone lock codes should not be counted as one of the required authentication mechanisms. Another technical requirement is to reauthenticate a subscriber every 12 hours or every 30 minutes if it is inactive. Moreover, a record retention policy (how long a user possesses access to data) should be used based on the governance strategy. Security and privacy risk considerations should be considered in this process shown in Table 8.

TABLE 7. Security and privacy risk considerations in a typical digital identity system (i.e., IdM).

Security/Privacy	Considerations	Mitigation strategy
Security	• Impersonation threats • Id proofing evidence falsification. • Id fraud. • Enrolment repudiation.	• validation of evidence personal details with issuers. • verification of biometric and given applicant evidence. • CSP should store subscriber biometric.
Privacy	• Data collection and minimization • Consent • Processing limitation • Redress • Privacy risk assessment • Data Protection Compliance	• Collect only the necessary PII needed for validation process (national ID should not be used unless necessary for Id resolution). • Applicants should be notified about the purpose of data collection. • Using measurement mechanisms ensure processing limitations. • Using mechanisms ensures dealing with applicant complaints. • Conducting risk assessment on dealing with PII. • Organization's data protection officer should be part of the IdM development team to ensure data protection compliance.

Federation is a process where the authentication credentials are conveyed in complex networked systems, between the subscriber, the Identity Provider (IdP) (the verifier, called CSP in authentication and proofing processes), relying parties (uses the credentials to authenticate and authorize a subscriber), and federation identity system. To ensure federation, an assertion process (statement includes an identifier and attributes of the subscriber sent from IdP to RP) is used. In federated IdM systems, a subscriber is authenticated by RP through a federation protocol, which allows a subscriber to connect with multiple RPs and provide a single-sign-on SSO service. To ensure the assertion process, a key management cryptographic mechanism is used to hinder RP impersonation of IdP in another RP. In addition to ensuring data protection and organizing the data sharing process, runtime decision mechanisms are used in which every RP and idP use a allowlist and blocklist to organize authentication requests. IdP should use mechanisms to ensure

TABLE 8. Considerations to ensure identity authentication and life cycle management.

Security/ Privacy	Considerations	Mitigation strategy
Security	• Assertion falsification or modification. • Authenticator duplication. • Authenticator secrets Eavesdropped. • Offline cracking using dictionary attacks. • Side Channel Attack. • Phishing or Pharming attacks by fooling subscribers with a fake RP entity. • Social Engineering. • Online Guessing. • Endpoint Compromise. • Unauthorized Binding.	• Using multi-factor Authentication. • Using secure communication endpoints. • Use hashed keys and strong entropy secrets (64 bits or more). • Using verifier impersonation resistance mechanisms. • Using limited retries. • Awareness of social engineering. • Use MitM-resistant mechanisms.
Privacy	Processing limitation, Privacy risk assessment and Data protection Compliance.	• Using measurement mechanisms ensure processing limitations. • Conducting risk assessment on for records retention. • Organization's data protection officer should be part of the IdM development team to ensure data protection compliance.

subscriber information is not exposed by other parties. While a subscriber communicates with IdP and RP using a browser, IdP and RP deal with each other in two ways, either directly between each other or via the subscriber, as shown in Figure 7. Multiple federated IdM models are in use, manual, dynamic, authority-base, and proxied federation [58].

The involvement of third parties (IdP) in the federation process ensures the need for privacy requirements. IdP keeps the information about subscribers' activities at RP. Therefore, the privacy officer should conduct a privacy impact assessment to ensure that IdPs do not act beyond the IdM process needs.

Assertions are an integral part of the federation process. It is a package statement (metadata) that includes Subject (subscriber) attributes, assertion identifiers, Issuer (IdP), Audience (RP), signature, authentication time, issuance timestamp, and expiration time. Assertions should be protected by including 1) identifiers, timestamp, and nonce (random number used to ensure assertion used once), 2) assigned using digital signature by the IdP (the user), 3) encrypting assertions by the IdPs, and 4) using restriction techniques restrict access to targeted RP. In addition, the protection of the communication between the subscriber, IdP, and RP should be ensured using authenticated protocol channels [58]. Security and privacy risk considerations should be considered in this process shown in Table 9.

Appendix G shows the technical requirements for IdM systems acquired from standards such as [47], which, according to [51] and [53], must be adhered to by new IdM models such as BC-IdM systems. Moreover, according to [37], the digital identity standards (aforementioned and explained) are

TABLE 9. Assertion process security and privacy considerations.

Security/ Privacy	Considerations	Mitigation strategy
Security	• Assertion modification. • Assertion Disclosure. • Assertion Repudiation by the IdP and subscriber. • Assertion Redirection • Assertion Reuse.	• Sign the assertion at IdP Cryptographically and verify at RP • Using authenticated communication channels. • Assign the assertion with keys cryptography and use key-holder mechanisms to ensure subscriber identity. • Adding audience identity (RP) and verifying it • Using timestamp and verifying it by RP
Privacy	• Tracking and Profiling • Notice and Consent • Data Minimization • Data Protection Compliance	• Minimizing subscriber profiling and tracking and ensuring only permitted processing. • Using mechanisms taking subscriber consent before sharing profiles with RPs. • Using mechanisms to minimize unneeded PII data exposure. • Organization's data protection officer should be part of the IdM development team to ensure data protection compliance.

not explicitly designed for specific domains and applications but designed generically to allow applicability to IoT system authentication processes, such as HIoT.

HIoT systems are considered heterogeneous environments where varied protocols are used to accomplish the system objectives. Although using BC-IdM in healthcare systems shows promise, it needs considerable computational resources, and thus, using it in HIoT comes with challenges because of the HIoT resource constraint. The complexity of the system mandates security and privacy requirements in the whole ecosystem, including sensor, personal, medical, connectivity, and data levels. Security and privacy requirements in HIoT include: 1) data level (medical data integrity, confidentiality, and availability according to GDPR and HIPAA), 2) sensor level (tamper-proof device, localization to ensure HIoT device location, over-the-air programming, and self-healing capabilities after attack incidence), 3) personal level (user and device authentication: only patients and trusted medical staff should be able to access personal server). To combat falsification from malicious devices, the device authentication process should be based on encrypted/secured communications and should be mutual between the personal server (smart devices) and HIoT device to tackle the constraints on the device side, 4) medical level (only authorized personals should have access to patient data, and data should be encrypted when stored in the database. This can be achieved by using access control mechanisms such as Attribute-Based Encryption (ABE), key management, trust management mechanisms, and Denial of Service (DoS) resentence solutions at the medical server level) [59]. HIoT still faces authentication issues in conventional IdM systems, e.g., the federated model. Therefore, BC-IdM should consider

and overcome the same issues related to HIIoT devices and user authentications.

II) BC-IdM PRINCIPLES/ PROPERTIES

BC-IdM systems should be built based on quality and functional principles that are compliant with laws, regulations, and standards. Thus, researchers in [60] have investigated the BC-IdM (SSI) principles, digital identity principles, security and privacy controls, and compliance with laws and regulations. They identified the BC-IdM consolidated properties that consider BC-IdM principles and eliminated duplicates. This resulted in the following twenty properties, as follows: 1) Existence: the existence of real users is a condition for creating a digital identity for them, 2) Sovereignty: the identity owner must have full control of the identity, 3) Single source: the identity owner should be the only source of creating credentials, 4) Data minimisation: a minimum amount of data should be disclosed when necessary, 5) Verifiability: credentials are the only method to verify the identity owner, 6) Decentralised: the identities should not be controlled using a centralised system, 7) Protection: the BC-IdM system should be protected using cryptographic mechanisms to ensure the CIA triad, 8) Availability: the IdM system should be available and accessible whenever a user identity needs, 9) Access: the identity subject should have full access to their data with no hidden data, 10) Transparency: the IdM system and its collection and processing operations should be transparent to the user, 11) Persistence: the system should provide identity longevity as the identity owner wishes, 12) Portability: it should support exporting identity and synchronizing across systems based on reliable standard and format, 13) Interoperability: BC-based systems' ability to exchange data with other stakeholders or between different systems, and must ensure compatibility with legacy identity management systems (e.g., previous used federated IdM systems), 14) Consent: sharing identity data should be based on user consent, 15) Recovery: it should offer mechanisms ensuring recovering when keys, data, identities, and credentials are lost, 16) Standard: it should be based on open standards to ensure sustainability, interoperability and portability, 17) Cost-free: apart from the implementation and recourse cost, it should offer the minimum cost possible to increase its adoption, 18) Scalability: it should support scalable identity systems to accommodate the increase number of identities, things, organizations and other entities, 19) Accessibility: the system should be user-friendly and accessible by lay users, 20) Sustainability: BC-IdM systems must be based on sustainable infrastructure.

III) SECURITY AND PRIVACY CONTROLS

Organizations can use different approaches to identify controls, by either using pre-defined security and privacy controls (baseline controls) or defining controls based on their needs. NIST 800-53 [26] pre-defined general security and privacy controls for information systems. However, it recommends

using specified controls developed for specific systems for the generality of these controls. Several researchers, such as in [60] and [61], identified the security and privacy controls in BC-IdM and HIIoT, which cover data flow between the IdM system, communication protocols, and the HIIoT system. Due to the research scope, we synthesized the general HIIoT, BC and BC-IdM security and privacy controls, as follows:

TABLE 10. HIIoT security and privacy controls.

1) 1) Access control	
Identification and authentication	1. Use user identifiers, device IDs, and complex passwords. 2. Token-based identification should be based on multi-factor authentication. 3. Restrict access privileges to devices. 4. Limit false access retries. 5. Workstation identification and update network table. 6. Use private connections for remote authentication.
Electronic access and hardware	7. Use asset theft detection measures and use authorization rules. 8. Assign unique identifiers with HIIoT devices for every user. 9. Use tampering resistance mechanisms and resistance mechanisms to side channel attack. 10. Restrict service ports use (hardware, drives). 11. Use encryption mechanisms with data storage. 12. Physical access based on tokens, and authentication mechanisms.
Internet	13. Separate internal network using Demilitarized Zone (DMZ) with subnetting capabilities. 14. Use a Virtual Private Network (VPN) with encryption capabilities. 15. Use proxy servers to act as buffers. 16. Use a firewall to actively monitor access to devices.
2) Computing and network controls	
Network isolation	17. Isolate internal networks from internet-accessed services. 18. Use a firewall to restrict nonbusiness process-related connections. 19. Use security and IdP to manage authentication and authorization between users and HIIoT devices. 20. Use Syslog servers.
Intrusion, detection prevention	21. Use Intrusion Detection Prevention Systems (IDPS). 22. Use domain name systems (DNS) for scanning detection.
Data transmission and transportation	23. Use mechanisms to protect the confidentiality and integrity of transmitted medical data, such as public key certificates and/or access control lists (ACLs). 24. Transmit only encrypted data outside secure areas. 25. Use secure network authentication protocols such as Extensible Authentication Protocol – Transport Layer Security (EAP-TLS), Remote Authentication Dial-In User Service (RADIUS), and (Wi-Fi Protected Access (WPA2).
Data and device disposal	26. Erase media from data before disposal and DECEMENT disposal procedures according to NIST-800-88 (Guidelines for Media Sanitization CSRC).

• General to HIIoT

HIIoT security and privacy controls are derived from NIST 800 series, ISO 27001 security standards, and medical-focused regulations and standards such as OWASP to ensure security requirements. Common threats in HIIoT mandated security controls to ensure confidentiality, integrity, and availability. Data leakage, medical information disclosure, and data tracking are critical threats in HIIoT systems that affect confidentiality. Other threats such as patient data tampering, HIIoT device impersonation, tampering, and communication modification are among the threats that affect data integrity, communication, and software authenticity in HIIoT. While Denial of Service (DoS), which targets different layers is a common threat in HIIoT systems and impacts the availability.

Controls and countermeasures should be used to secure the data, personal, hardware, software, and network layers against these threats and ensure CIA. Security and privacy controls that prescribe the measures to secure HIoT systems are divided into five groups, as shown in Table 10 and 11.

TABLE 11. HIoT security and privacy controls (continuation).

3) Software controls	
Anti-malware	27. Use up-to-date malware software compatible with used technologies in the HIoT systems.
Operating system Hardening	28. Delegate limited administrative accounts. 29. Use security software and policies. 30. Restrict unnecessary network protocols, services, and applications. 31. Use user authentication systems.
Product upgrades	32. Upgrade patches should be on-site and only use controlled remote firmware updates.
Logging and Monitoring	33. Use security logs mechanisms with HIoT and monitor them periodically for security warnings.
Data	34. Process data purposefully. Use data encryption techniques either at rest or in storage. 35. Use privacy preservation mechanisms to ensure anonymity of patient data.
4) Wireless controls	
Wireless connections	36. Use wireless network encryption mechanisms. 37. Change the default service set identifier (SSID) on access points. 38. Use complex passwords.
Bluetooth connections	39. Using Bluetooth security mode 3 is preferable. 40. Perform the pairing process. 41. Deactivate unneeded Bluetooth capabilities. 42. Use authenticators means, such as biometric and multi-factor authenticators.
Portable device medical	43. Forbade using personal devices on networks. 44. Forbade storing, processing, downloading, or transmitting data on personal and portable media. 45. Apply Bring your own device (BYOD) policy when needed.
5) Training and Education	
Organizational controls	46. Develop an impellent training strategy. 47. Rise security awareness concerning basic activities and evolving issues. 48. Produce security manuals and guidelines. 49. Use technology in training and awareness programs. 50. Provide leveled training based on the specialty and tasks. 51. Monitor and measure the training effectiveness.
Other controls	52. Guidelines of the code of data exchange and interchange. 53. Guidelines on risks of using communication tools irresponsibly.

- Specific to BC:

It includes the core assets of BC. Table 12 shows BC components' security and privacy controls, i.e., the P2P network, the Distributed Ledger, consensus mechanisms, and Smart Contracts.

- Specific to BC-IdM

To assist in developing BC-IdM systems compliant with GDPR and IdM systems standards, the BC-IdM system specified security and privacy controls are shown in Table 13 and Table 14.

IV) HIoT BC-IDM SECURITY POLICIES

An information security policy is a general statement that includes rules on how an entity should behave within an organization to ensure secure information management and distribution. It is derived from directives, regulations, rules, and best practices and used by organizations to control entities' behavior in dealing with resources. They

can be divided based on the purposes of 1) program policy, 2) system-specific policy, and 3) issue-specific policy. To implement a security policy, an organization develops more precise standards, procedures, and instructions to accomplish a security policy [62]. Some security policies are identified and can be applied in HIoT BC-IdM, shown in Table 15.

TABLE 12. BC security and privacy controls.

P2P network	1. Use quantum computing-safe cryptographic mechanisms. 2. Ensure concurrent connections and ensure timeout limit. 3. Ensure integrity of unicast, multicast and forwarding communications. 4. Use network security audit mechanisms. 5. Ensure node identification. 6. Ensure Membership Service Provider (MSP) security.
Distributed ledger	7. Use strict ledger access control. 8. Use standardization of the ledger to ensure software fault tolerance. 9. Ensure ledger data integrity and confidentiality. 10. Ensure data synchronization in the ledger. 11. Use mechanisms to prevent data repudiation. 12. Ensure ledger data idempotence (ledger should function without faults).
Consensus mechanism	13. Monitor and ensure consensus effectiveness and consistency. 14. Using 51 attack prevention techniques. 15. Use real-time backups.
Smart contract	16. Perform entity identification and authentication. 17. Ensure transmission integrity and data confidentiality of SC. 18. Use security audit mechanisms to ensure event and record security. 19. Using SCs analysis tools to analysis from malicious code and use measurements of analysis tools.

The structure of security policies differs according to its type and normally addresses purpose, scope, responsibilities, and roles.

V) DATA FLOW IN BC-IdM HIoT

Showing data flow between BC-IdM HIoT assets and stakeholders is essential to identify security and privacy risks. To prepare for systematic risk assessment, we develop the stacked architecture model in Figure 8 (A) below. Details of the HIoT BC-IdM system derived from [1], [2], and [63], depict the data flow between the HIoT high-level system, IdM ecosystem, and BC assets, which run on top of each other. The architecture model consists of Blockchain and HIoT application components.

- **Blockchain components:** It includes the following:

- Network layer: consists of the underlying network, BC public and private network services. The underlying network component deals with the network's underlying infrastructure, such as routing protocols and Domain Name Systems (DNS), which facilitates BC public and private networks to run peer-to-peer, authentication, and access control services.

TABLE 13. BC-IdM security controls.

Security controls	1. Data integrity: using a digital signature to sign and authenticate data message, using secure channels to share keys used in signing messages and verification processes, using digital timestamps, and using collision-resistance hash functions. 2. Data confidentiality: using cryptographic independent and unpredictable modules to ensure sensitive data confidentiality, which supports forward and backward secrecy. 3. Data availability: rescues should be available whenever needed. 4. Authentication: user registration, de-registration, revoking procedures to manage identities and access, using user identifiers, external connections, networks, and equipment authentication. 5. Authorization: user privilege allocations should be controlled defining user roles and responsibilities. 6. Accountability: using log systems and keep compliance evidence (token measurements). 7. Non-repudiation: denying a false rejection/ refusal of an obligation should be by two parties with irrefutable evidence. 8. Validation and sanitization: validating input/ output data from the application to ensure the correctness and appropriateness of data and information and using data validation and sanitization mechanisms to ensure data accuracy. 9. Error handling: using secure safeguards to protect personal data from breaches and using validation mechanisms in applications to detect information corruption caused by deliberate or functional errors. 10. Key protection: using key management techniques to ensure secure sharing and management of public and private keys. 11. Malware protection: Using antimalware software to prevent damage and access to data. 12. Communication security: ensure necessary and safe network services can be accessed, data should be exchanged securely and not disclosed, and Data should be transmitted using secure channels. 13. Physical and environmental security: organizations should only authorize specific individuals to have access to systems, services, and equipment. 14. Password security: using password management means (e.g., password suspension and aging). 15. Configuration security: control of logical and physical access to configuration ports, using sequential order to the application business flow, handling untrusted files securely, and sitting security by default configurations in the application infrastructure. 16. Session security: session should be limited by limited time, using additional restrictions on applications incorporate high-risk data, and using mechanisms to ensure PII privacy. 17. Data classification: data controller should classify data based on asset criticality.
-------------------	--

TABLE 14. BC-IdM privacy controls.

Privacy controls	18. Access control: users should hold valid credentials, access control privileges should be limited and based on classification levels, access control should be based on access needs, and access and identity suspension and termination procedures should be in place. 19. Consent: using mechanisms ensuring user consent; data users should gain consent from the data owner before processing data. 20. Fairness and lawfulness: data should be processed lawfully and according to data protection rules. 21. Purpose specification and limitation: data should be collected purposefully and accessed data should be limited to the purposes. 22. Collection limitation: data collection should be done securely and fairly after getting the data subject consent. 23. Use, retention, and disclosure limitation: data user is responsible for holding data purposefully; when the purpose is fulfilled, the data user should delete personal data. 24. Data accuracy and quality: personal data must be relevant to the purposes for which they are accessed, and they should be accurate. The data subject has the right to edit/delete data when discovering inaccuracy. 25. Data minimization: data exposure should be minimized to the access purpose. 26. Data erasure and rectification: data processor should erase personal data when retention time is reached. Data should be erased upon data subject request upon service ceased, in case of consent withdrawn or in case of breaking the data protection law. 27. Data recovery: using mechanisms ensuring recovery when keys, data, identities, and credentials are lost. Back-ups should be stored separately from original assets. Integrity should be checked when resorting data. 28. Notification: Data users are required to present privacy notice to the data subject before collecting and processing data. Customer should be notified by an organization about binding requests to disclose personal data, personal information authorities and individuals should be notified when data is breached, and remedial actions should be taken immediately, and consent and privacy notices should be used before accessing online children-related information. 29. Transparency: processing personal data should be transparent to the data subject. 30. Individual participation: data subjects should have the right to know whoever controls their data, access, and alteration to their data; if the request is denied, they should be given reasonable reasons. 31. Portability: should use means to allow data portability whenever the data subject requests it.
------------------	--

- Consensus layer: consists of the BC consensus mechanism, which is used to validate transactions. They differ from one BC to another, such as Byzantine Fault Tolerant (BFT), Proof-of-Resource (PoR), and Proof-of-Stake (PoS).
- BC Data layer: transactions are interpreted in this layer. This layer includes BC and smart contracts transactions for data security and user privacy.

• **HIoT application components:** HIoT application components facilitate the end-user services and functionalities and are divided into the BC-IdM ecosystem and the high-level system, as follows:

- 1) the BC-IdM ecosystem, which represents the systems that provide BC-IdM functionalities for HIoT high-level applications, which includes:
 - Layer 2 protocols: protocols used in BC-IdM systems to provide scalability to DID systems in which the system activities are offloaded from BC. Sidetree protocol is an example of Layer 2 protocols.
 - DID systems: systems used in BC-IdM systems to create a secure channel between entities to allow authentication without a need for centralized registration.

TABLE 15. Identified security policies used in BC-IdM HIoT systems.

Policy	Purpose
Identity and access management policy	Ensures that the use of information resources is in accordance with information security and business requirements.
third party data collection/distribution policy	To govern data collection, distribution, and ensure user/individual data protection.
Record retention policy	To ensure data is used and disposed after a limited time.
Token use policy	It defines token use lifetime and format.
Account management policy	It organizes how an account is created, used, revoked.
Usage policy	It sets restrictions on the access to information resources.
Segregation of duties policy	To ensure segregate actions done by individuals in the IdM system.
Bring Your Own Device (BYOD) policy	It organizes the use of devices for work purposes.

- Wallets: applications used by users to store identifiers and credentials.
- Oracles: are trusted third parties that provide services to connect the SCs and BC data with external systems such as HIoT and visa versa.
- Storage methods: off-chain storage used to store ID data, such as IPFS, CouchDB, and OrbitDB.
- Exchange methods: data exchange methods such as JavaScript Object Notation (JSON)

and JASON Web Token (JWT) are used to manage the process of requesting and issuing credentials.

- 2) a high-level system that provides end-user functionality and allows communication between system stakeholders, e.g., HIoT users, third parties, and health institutions, as shown in Figure 8 (B). It shows the general data flow between the system's main components, which are applicable to all BC infrastructures, i.e., the most used BC for BC-IdM systems, Ethereum, Hyperledger Fabric, and Hyperledger Indy, according to our previous literature study [2]. The figure shows the three main entities of the high-level HIoT BC-IdM system, HIoT user (ID holder), health institution such as a hospital (ID issuer) and third-party service prover (ID verifier), and the main technologies used (i.e., BC and IdM ecosystem technologies). Every entity won a digital wallet to perform the ID registration and authentication processes. BC and IdM components and technical standards ensure the digital wallet sign, access, and proof processes.

For the diversity of BC technologies and HIoT systems, we showed the general data flow to the main components of the HIoT BC-IdM system and the detailed model showing the back-end technologies to show related overall risks. However, cybersecurity risk management standards recommend using specific scenarios to exemplify the risk management process. For example, Hyperledger Fabric as a BC infrastructure with Medical IoT (MIoT) as a type of HIoT can be used as a scenario to show the exact data flow in such systems. Therefore, health organizations should draw a specific Data Flow Diagram (DFD) for the BC used in the IdM system, as the detailed security risks vary from one BC to another.

2) ASSESSMENT PHASE

In this phase, the core of the risk assessment process is conducted based on the risk methodology identified in the framing phase. The assessment process includes security and privacy threat and vulnerability identification, impact assessment, and risk determination.

a: THREATS AND VULNERABILITIES IDENTIFICATION

A number of cybersecurity risk assessment and analysis approaches were derived from the research used sources, i.e., grey literature review (standards), academic publications, and expert interviews (combined and synthesized) are recommended to be used to identify security and privacy threats in HIoT BC-IdM. STRIDE and DREAD are qualitative and quantitative methodologies widely used to identify security threats in information systems. STRIDE is a qualitative method that categorizes threats into Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, and Elevation of privileges. On the other hand, DREAD is a quantitative method that classifies the threats

into Damage, Reproducibility, Exploitability, Affected users, and Discoverability. Although DREAD is not recommended to rely on in threat identification solely as it is subjective, it can be used to prioritize threats. LINDUNN is a qualitative method similar to STRIDE but used for privacy threat identification. It classified the privacy threats into Linking, Identifying, Non-repudiation, Detecting, Data Disclosure, Unawareness, and Non-compliance threat classifications. It is compatible with STRIDE and encouraged to be used together. In several studies, attack trees were used instead of STRIDE as a tool to identify threats. Having identified the assets and general data flow between HIoT BC-IdM components in the framing phase, we follow the assets-based risk assessment and analysis approach and use STRIDE and LINDUNN method categorizations. Security and privacy threats are dynamic and come in different forms, initially as threats that eventually cause attacks and privacy breaches. Appendices H, I, and J summarize threat sources, vulnerabilities, and categories based on the impacted assets of HIoT BC-IdM systems. They are derived from the reviewed studies in our previous review studies [1], [2], and evaluated by the interviewed experts.

b: IMPACT ASSESSMENT AND RISK DETERMINATION

Risk determination is based on the threat impacts, which depend on occurrence likelihood. Identifying the likelihood of occurrence is important to determine the threat impacts. Occurrence likelihood determination depends on inputs from historical data on cyber attack consequences (how many times it occurs), its impact, detection rates, and empirical data [39]. Following this strategy helps the security risk assessors not to check everything but focus on the most potential and impactful attacks. Therefore, as the solution under investigation has no real-life applications, we rely on potential risks and impacted stakeholders that are identified in the literature. There are two types of risks: 1) Inherent Risks, which are the risks that exist before implementing the mitigations. 2) Residual Risks, these are the risks determined after applying the mitigations. The output of the assessment phase includes security assessment reports, which include threats, vulnerabilities, and risk assessment reports, including inherent risks. Potential security risks caused by the threats and vulnerabilities [42] are:

- loss of HIoT user privacy.
- loss of system user privacy such as medical staff.
- loss of the reputation of regulatory bodies and medical service providers such as hospitals, medical insurance, and HIoT manufacturers.
- disruption in services' functionality.
- risking HIoT user safety.

3) TREATMENT PHASE (RESPONDING TO RISK)

Treatment alternatives to the identified Inherent risks are addressed in this phase. Risks either be accepted, avoided, transferred, shared, or mitigated according to the risk tolerance and appetite, which should be decided in the

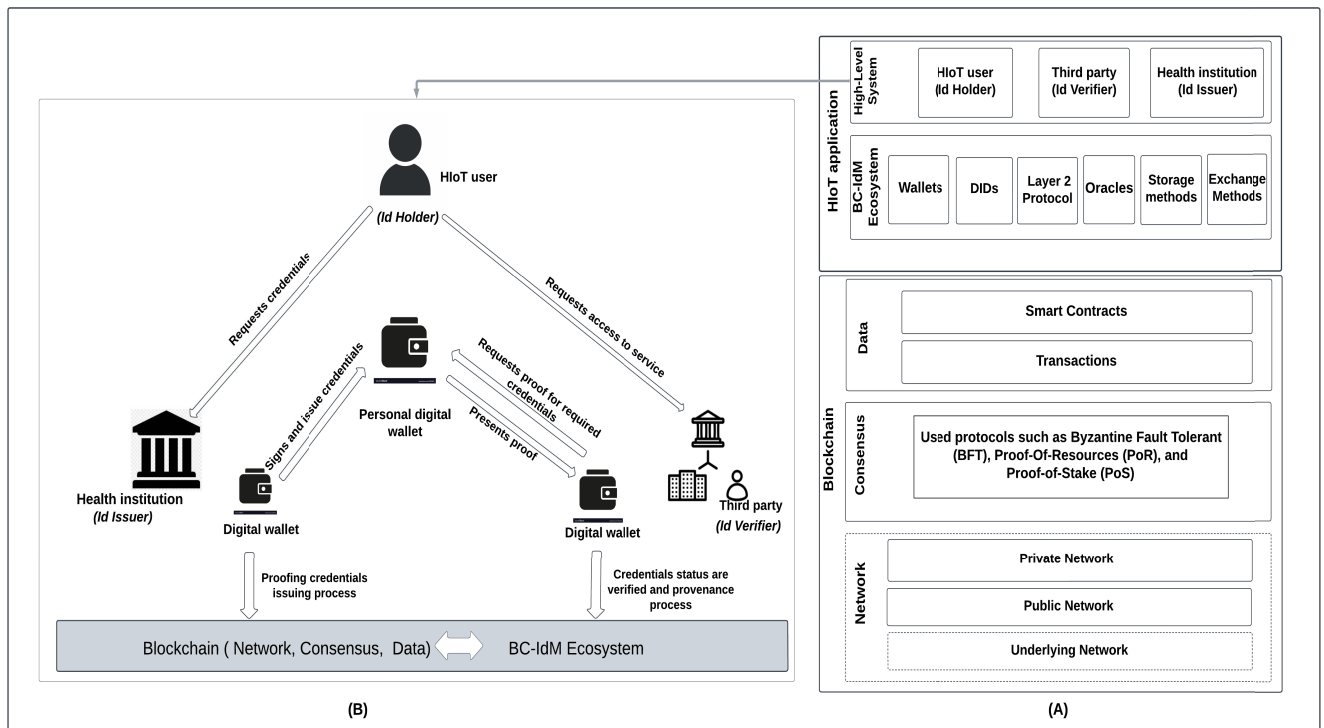


FIGURE 8. The risk assessment stacked model shows (A) details of BC-IdM in HIoT for the risk assessment process and (B) the communication between the HIoT BC-IdM stakeholders.

preparation phase. Risks are accepted when risks are within the organization's risk tolerance level, while avoided when they exceed the level. They can be avoided by eliminating the activities/ technologies that trigger this type of risk and using alternatives that fit the needs. Risks can be transferred (entire responsibility) or shared (a portion of responsibility) to another qualified organization to tackle the risks. Risks are mitigated using management and technical countermeasures, i.e., organizational security policies to strict using technologies, and technical controls and countermeasures to control risks to an accepted level, such as using multi-authentication mechanisms ensuring the user security and privacy by enforcing only connecting with secure HIoT devices (not counterfeit) and preventing the data breach and leaks. When the countermeasures are identified, they are implemented and evaluated. Evaluating the countermeasures is done in this phase to ensure effectiveness. Controls that were identified in the preparation phase can be used to evaluate the countermeasures to ensure the functionality, security, and privacy of BC-IdM systems. Residual Risks are determined after applying the countermeasures. Recovery plans for the system are recommended in this phase to ensure system functionality and user security and privacy according to the countermeasures evaluation.

4) RISK MONITORING AND REPORTING PHASE

In this phase, treatment decision implementations are verified and monitored, and security controls and compliance are

evaluated. Results from previous phases are communicated with other stakeholders in this phase. Report and risk observations are communicated with stakeholders, such as the mitigation owner, risk owner, and decision-makers. Moreover, as threats are dynamic, identified threats and vulnerabilities should be updated continuously, which mandates continuous monitoring and updating of security controls and policies. Risk assessment should be conducted frequently because new might emerge, some BC is improved in overcoming some vulnerabilities, or when there is a plan to use a new technology or feature or update the system. The produced risk assessment report and common vulnerabilities databases, such as The Open Worldwide Application Security Project (OWASP), can be used to keep up with new vulnerabilities.

Because of the potential changes and updates, outputs from this phase can be inputs to previous phases (preparation, assessment, treatment). An effective cybersecurity risk management process is a continuous process [38]. BC-IdM systems and cybersecurity vulnerabilities and solutions are evolving. Therefore, short and long-term evaluation processes to the cybersecurity risk management process are recommended. A long-term repetition should be conducted according to the risk management strategy. It is usually done annually. The short-term evaluation usually takes place after finishing the risk assessment process to ensure that the taken countermeasures meet the security and privacy controls and requirements. Doing so helps make changes in case new weaknesses are found or new solutions are prevailed [1].

Monitoring, compliance, and governance reports play a role in the decisions taken by organizations about the change in all the cybersecurity risk management process phases. Compliance with data protection is essential to evaluate the effectiveness of treatment decisions.

C. TOTAL EVALUATION AND SOLUTION COMPARISON OF BC-IdM IN HIoT

The last two processes in the developed framework after finishing evaluating the four aspects are the total evaluation and solutions comparison. Making a decision in selecting the most suitable security solution is essential to ensure HIoT security and privacy. It should be based on a concrete evaluation process. MCDM techniques are used widely in evaluating and making decisions in IT solutions in general and in BC-based applications [64]. Several studies compared different IdM system models, such as BC-IdM and federated IdM, and suggested evaluation factors to be used in the evaluation process [65], [66]. According to our previous studies and the experts' feedback, four aspects should be evaluated in order to select the most suitable BC-IdM solution for HIoT systems, security and privacy, HIoT-related aspects, technical and external aspects. BC technologies and IdM models should be compared in this stage. BC solutions are varied in type. There are main BC platforms (i.e., Ethereum, Hyperledger Fabric, Corda, Indy, NEM and Bitcoin). On the other hand, there are BC technologies built upon these BC platforms, such as IBM Blockchain, Quorum, Multichain, Elements, and others. Appendix B gives more details about the BC technologies and a comparison between them according to Network Type, Consensus mechanism, Cost, Support Community and governance, and Origin. Regarding IdM systems, three main IdM system models exist. Classical centralized IdM, Federated IdM, and user-centric IdM model (decentralized). BC-IdM systems is an example of a user-centric IdM model where the main goal is to eliminate the reliance on the centralized party by allowing the ID owner to control access to the data (privacy) and to eliminate the single point of failure issue (security). Centralized IdM is the classical IdM system. While the federated, which is used widely nowadays, is based on giving authority to second-layer identities to manage access. These are federation proxies that generate tokens for entities that request access, like using a Google account to play the federation role in accessing other online accounts. While this guarantees the data owner to give consent to access to data, it entrusts Google with data, which is critical for privacy preservation. In contrast, in the decentralized model, two entities communicate without putting trust in third parties using BC, DID systems and mechanisms like the zero-knowledge proof technique to ensure decentralization and privacy. The centralized and federated models suffer from the single point of failure and connectivity failure issues (the federated relies on a centralized system indirectly) however, they provide reliable functionality. In contrast, the

BC-dM has the potential to be more secure, however, the functionality of BC-IdM is yet to be mature. BC-IdM is an extension of the federated model; however, it suffers from functional issues in the federation part of the system, (validation process). Therefore, it needs more improvement. Appendices C and D give more details about the IdM models and BC-IdM available tools. Results from all four evaluation aspects should be inputs in the total evaluation and comparison steps. Besides security, privacy, and HIoT-related aspect evaluation results, supposing that evaluation results from technical and external aspects are acquired, evaluation reports from cybersecurity risk management, technical, and external aspects should be inputs in the comparison process. The organization's decision-makers can use the total of FGW that are assigned to the evaluation factors to evaluate and select between IdM solutions, including BC-IdM and conventional IdM systems for the HIoT systems.

VII. DISCUSSION

BC-IdM systems proposed for HIoT do not consider all security, technical, and external aspects of BC, IdM, and HIoT application considerations. To develop a functional and secure BC-IdM system for HIoT, there was a need to develop an evaluation framework that considers all essential aspects, i.e., security and privacy, HIoT application-related considerations, technical and external aspects. An evaluation of the cybersecurity risk management and evaluation framework for the BC-IdM system in HIoT is conducted in this work. It includes findings from interviews from the First Round and a questionnaire from the Second Round of the Delphi method. The overall outcomes are reflected in the cybersecurity risk management and evaluation framework details.

Although many studies proposed BC-IdM for HIoT systems and claimed potential, they lack concrete and reliable evaluation and cybersecurity risk management references. Several studies were identified that contribute to tackling the issue of security risk assessment and evaluation of BC-based applications. However, our work stands out by focusing on BC-IdM evaluation and cybersecurity risk management of BC-IdM for HIoT. The developed framework uncovers all the aspects that should be considered before applying BC-IdM in HIoT systems. Although the framework focused on the cybersecurity risk management process, all other evaluation aspects were also identified in this study.

There is a potential for using BC in healthcare after some successful applications in financial and promising solutions in some sectors like supply chain management. BC-IdM has the potential to be a better solution and outweigh federated and centralized IdM systems by providing privacy and eliminating the single point of failure. It can allow data subject controls to generate the data, control how to use the data and control how to revoke data. However, BC-based IdM systems lack regulations in general. Data protection regulations around the world are general and do not consider BC applications until the time of conducting this research. That is because of the nature of BC, as it

is based on a decentralized paradigm and evolving quickly. Another main issue is the increased security threats and risks from BC assets. As explained in the previous sections, the high-level HIoT system relies on the BC-IdM ecosystem and BC technologies, which suffer from security issues. Moreover, when BC-IdM is used for HIoT, the complexity is increased. The inherited issues of the conventional IdM systems used in HIoT are still issues in the BC-IdM systems. HIoT, as any IoT system, suffers from access and management (identification and authentication) issues due to the complexity and constraints in the design of IoT systems, as discussed in previous sections. HIoT user identification should be guaranteed. Ensuring the identification of the valid user of the HIoT device is an open issue. The underlying hardware is a source of threats; whether it is installed or authorized from a legitimate source; i.e., third parties and vendors.

Evaluation of the solution before applying it is pivotal. From the experts' experience, some organizations tend to focus on how to utilize new technology rather than the added value. The decision-making process should follow best practices when it comes to changing IT infrastructure such as IdM systems. Organizations intending to upgrade the IdM system and adopt BC-IdM systems need to consider the following points:

- Organizations should check on the regulation's availability, compliance, and governance before investing in such systems. There should be cooperation between governments and service providers, nationally and internationally, on how to process data in BC-IdM systems. Thus, GDPR and other data protection regulations should be aligned. Until now, there has been no agreement between countries regarding BC-IdM systems. Regulatory bodies in charge of data protection regulations should extend them further to cover BC-IdM systems for their importance in processing individuals' data. For the fear of the government breaching the privacy in the BC-IdM systems, the judiciary might need to be involved to ensure transparency, according to experts.
- A gap analysis should be conducted initially whenever a new technology is planned to be used. The evaluation process plays an important role in the organization's gap analysis process. Organizations should start with gap analysis, application requirements, and proof of concept to ensure the functionality, security, profitability, and applicability of this new system. A gap analysis process should be done before adopting BC-IdM solutions where the developed framework can play a beneficial role. After finding the gap (e.g., privacy of patient), there should be an investigation on whether there is a need for a whole change or customization to an existing system or if new requirements are enough. When a decision is made to use the BC-IdM system for HIoT, such an organization should check the readiness in terms of workers; there is a need for knowledgeable

TABLE 16. Expert details.

#	Ex. code	Expertise	Years of expertise	Qualification	Organization	Round 1 Interview (date)	Round 2 Ques.
1	BCIDE1	Blockchain + IdM systems+ health informatics	6 years	Academic and researcher (PhD)	Academic institution	Yes (13 March)	Yes
2	BCBU2	Blockchain + Business management	5 years	Blockchain researcher (MSc)	Academic institution	Yes (8 April)	No
3	BCH3	Blockchain + Cybersecurity+ health informatics	4 years	Academic and researcher (PhD)	Academic institution	Yes (19 May)	Yes
4	HloTE1	Health informatics + medical device security + data protection regulations	10 years	Data protection officer in health organization (MSc)	Regulatory health organization	Yes (4 March)	Yes
5	HloTE2	Health IoT cybersecurity	8 years	Academic and researcher (PhD)	Academic institution	Yes (18 May)	Yes
6	HloTE3	Cybersecurity + health informatics+ risk management	10 years	Data protection officer in health organization (MSc)	Regulatory health organization	Yes (12 May)	No
7	CSE1	Cybersecurity + IoT+ risk management	6 years	Academic and researcher (PhD)	Academic institution	Yes (31 March)	Yes
8	CSE2	Cybersecurity risk assessment	19 years	Cybersecurity risk management consultant (PhD)	Cybersecurity consultation	Yes (15 May)	Yes
9	CSE3	Cybersecurity +IoT+ risk management	14 years	Academic and researcher (PhD)	Academic institution	Yes (27 March)	Yes
10	CSE4	Cybersecurity risk assessment +IoT cybersecurity	6 years	Academic and researcher (PhD)	Academic institution	Yes (1 June)	Yes
11	IdME1	Identity and access management + BC solution initiatives	11 years	Security manager for IdM systems (MSc)	Leading petrochemical company (industry)	Yes, (20 May)	Yes
12	IdME2	Identity and access management +IoT systems (vehicle of things)	6 years	Security manager for IdM system project (key management system) (PhD)	leading car company (industry)	Yes, (1 June)	Yes
13	IdME3	BC- based Identity management systems	20 years in security (5 years in BC-IdM)	Academic and researcher (PhD)	Academic institution	Yes, (5 June)	Yes

people to maintain the BC-IdM solution itself. Also, the availability of the BC-IdM support community for the HIoT BC-IdM system should be guaranteed. After that, an organization needs to rely on a trusted vendor. After finding a trusted vendor, they should be provided with demonstrations from vendors, to check the pros and cons internally with the organization's requirements and link it to the gap analysis outputs. This evaluation can be done using the developed framework using MCDM, and based on the outputs from it, the decision-makers decide whether to invest in these technologies or not.

- According to the experts, one of the challenges to applying such systems is the acceptance by users. From their experience, hospitals hesitate to adopt emerging technologies like BC-IdM systems. Therefore, evaluating the acceptance of such solutions by HIoT users and raising awareness among system owners and users is vital.

TABLE 17. Blockchain platforms comparison.

#	BC	Network Type	Consensus mechanism	Description	Cost	Support Community	Industry-focus	Origin
1	Ethereum	Permissionless/ supports permissioned	Proof of Work/ Proof of Authority	Public BC started as a financial BC and developed to cover industry applications	Yes	ethereum.org + Ethereum developers	Cross-industry	Original BC
2	Hyperledger Fabric	Permissioned	Voting-based (Solo, Kafka or pluggable consensus)	Modular for Business use cases	No	Hyperledger foundation	Cross-industry	Original BC (Part of Hyperledger Project)
3	Bitcoin	Permissionless	Proof of Work	Public BC	Yes	Bitcoin	Financial	Original BC
4	Indy	Permissioned, Permissionless	Redundant Byzantine Fault Tolerance	BC-IdM systems (SSI)	No	Hyperledger foundation	Cross-industry	Part of Hyperledger project
5	Corda	Permissioned	Voting-based	Started as a financial BC and is evolving to provide cross-industry applications (undergoing)	Yes	R3 Consortium	Financial+ enterprise	Original BC
6	Quorum	Permissioned	Voting-based consensus mechanism	Started as a financial BC and is evolving to provide cross-industry applications (undergoing)	Yes	ConsenSys organization	Financial+ enterprise	Fork of Ethereum
7	Multichain	Permissioned	round-robin type scheduling	Enhancement is undergoing in this platform to help both across-Blockchain applications	Yes	Coin Sciences	Financial+ enterprise	Fork of Bitcoin
8	IBM Blockchain	Permissioned	Voting-based (Solo or pluggable consensus)	Hyperledger Fabric-based projects provider (Blockchain as a Service)	No	IBM	Cross-industry	Fork of HLF (BaaS)
9	NEM	Permissioned, Permissionless	Proof of Importance	Financial BC with enterprise application promises	Yes	NEM Foundation	Financial+ enterprise	Original BC
10	Elements	Permissioned	Strong Federations	Financial BC with enterprise application promises	No	Elements organization	Financial+ enterprise	Fork to Bitcoin
11	Cardano	Permissionless	proof of stake	Public BC started as a financial BC and developed to cover industry applications	Yes	Cardano Foundation	Financial+ enterprise	Original BC
12	Avalanche	Permissionless/ supports permissioned	Avalanche Consensus	Public Blockchain	Yes	Ava Labs	Cross-industry	Original BC
13	Solana	Permissionless	Proof of history	Public Blockchain	Yes	Solana Labs & Solana Foundation	Cross-industry	Original BC

- The verifier/ issuer of identities in BC-IdM is still an open issue. It should be chosen carefully. The availability of a verifier/ issuer is a critical aspect in BC-IdM. They should always be available. BC-IdM systems are in the early stages. They try to make a tripartite between issuer, verifier, and user, which is very complicated. Thus, there is a need for more studies on the single point of failure concept in BC-IdM systems. Nowadays, several BCs use cryptographic mechanisms responsible for distributing cryptographic keys in BC-IdM systems. They are considered trusted authorities, such as IMB BC trust anchor. Making governmental agencies the issuer in the BC-IdM systems boasts the BC-IdM applicability and functionality. If all privileges are given to the ID/data owner, the risk might rise first in case the ID/data owner is tempering with data (e.g., deleting their account). So, giving the right privileges to the ID owner by the governmental issuer is important [53].
- Although there are promising BC-IdM solutions, their maturity needs more improvement to replace the conventional IdM systems. BC-IdM systems based on BC, such as Hyperledger Fabric, are not fully decentralized. However, the SSI model can be achieved when combining another SSI BC protocol, such as Hyperledger Indy, with a permissioned Hyperledger Fabric BC, which can be a suitable solution for HIoT,

because of the HIoT application-related considerations, i.e., permissioned BC network.

- The lack of BC-IdM frameworks and standards hinders health organizations from adopting its applications for real-life applications. However, some sectors and applications are more advanced in this regard, such as BC financial applications in Banking. Adopting frameworks from the financial sector can be beneficial to facilitate the process of regulating BC-IdM applications in healthcare and other domains.
- In the context of the IdM of HIoT, authentication and authorization of the HIoT device are concerns. Ensuring HIoT identification accuracy outside health settings is a big challenge. Privacy breach is another big concern in HIoT. As HIoT is constrained, vendors use other geolocations to store data, and as HIoT is mostly used outside the health settings' security measures, e.g., hospital networks and firewalls, this might lead to data leakage. HIoT is at more risk when it is used outside hospital premises. HIoT rarely complies with data protection regulations. If BC-based solutions overcome these issues, they can outweigh classical IdM systems. HIoT IdM systems suffer now from security risks, and risks are expected to double after adopting BC-IdM if they are not regulated. These issues should be addressed, and appropriate security solutions, such as firewalls, intrusion detections, and encryption

TABLE 18. IdM models comparison.

IdM model	Description	Advantages	Disadvantages
Centralized (traditional)	Siloed IdMs allow direct interaction with systems by creating credentials specifically for such systems.	Basic login functionalities.	Single point of Failure, privacy, security, poor user experience
Federated IdM	Federated IdMs allow users to use the same credentials with different systems (services).	Good user experience (SSO)	Single point of Failure and Privacy, security, third-party reliance
User-centric (Decentralized IdM)	Decentralized IdMs like BC-IdM follow a user-centric IdM model by allowing users to interact with relying parties without a need for an intermediary.	Decentralization (custody control of identity data)	Regulations, standardization, and maturity.

TABLE 19. BC-IdM tools comparison.

#	BC-IdM	Used Blockchain	Description	Applications	Maturity
1	Sovrin	Indy (public-permissioned BC)	Indy BC-based open-source sovereign identity framework	Cross- industry	Comes in the first rank as it is supported by a multivendor consortium
2	Civic	Ethereum	Mobile application based on Ethereum BC to	Cross- industry	Follows Sovrin in maturity
3	Uport/ Serto and Veramo	Ethereum	IdM system based on Ethereum allows registering identities to request and send users credentials.	Cross- industry	Follows Sovrin in maturity
4	Blockpass IDN	Ethereum	IdM system based on Ethereum used to manage the self-verification process.	Cross- industry	Needs improvement to meet BC-IdM requirements
5	ShoCard	Any	Mobile app used to store user identity hashes in BC to better control personal data.	Cross- industry	Under development. The IdM process is still done by service providers (Federated IdM)

mechanisms, should be developed considering the nature of BC-IdM systems and HIoT application-related requirements.

- Because of the potential additional cost caused by BC, the health insurance model might be impacted. How BC affects the health insurance model is an open research issue and a very important aspect to be addressed by governing and regulatory bodies.
- As there is a lack of mature standards around the evaluation and assessment of BC-IdM system, IdM, functional requirements from classical IdM standards should be used to evaluate BC-IdM systems.

VIII. LIMITATIONS AND FUTURE DIRECTION

This work gave more focus on security, privacy and HIoT-related considerations by proposing a cybersecurity risk management framework. The technical and external factors were identified, and weights were assigned to them by experts. Using assigned weights, organizations that intend to develop BC-IdM for HIoT systems will be able to

TABLE 20. HIoT BC-IdM main and secondary assets.

Main Asset (MA)	Secondary assets (SA)	Description
HIoT system	HIoT device (sensors)	E.g., a device used by a patient.
	Remote monitoring system	Systems used by hospitals and patients including APIs and systems interfaces to interact with HIoT. It mainly consists of a personal server and a medical server.
	(Personal and medical server levels)	
	Network connectivity	Includes Cloud and network capabilities used in the HIoT BC-IdM.
BC infrastructure	Data	Data belongs to patient staff and vendors.
	BC network	Includes the BC P2P main components, nodes, distributed ledgers, and cryptography mechanisms.
	Consensus mechanism	Cryptographic mechanisms are used to run the BC network, by reaching an agreement between participants.
IdM ecosystem components	Smart contracts	BC-IdM uses SCs to build their logic.
	Decentralized Identifiers (DIDs)	Protocols designed to achieve the BC-IdM functionalities.
	Verifiable credentials (VC)	Protocols designed to achieve the BC-IdM functionalities.
	Verifiable presentation (VP)	Protocols designed to achieve the BC-IdM functionalities.
	Wallets	An application allows identities to store their private keys.
	Tokens	ID data is usually in the BC-IdM system process, identification, authentication, and authorization. processes are sent in the form of tokens.
	Mobile device	Used to control personal wallet.

TABLE 21. International cybersecurity risk management standards.

Standard	Title	Scope
NIST 800-12	An Introduction to Information Security	General information security
NIST 800-37	Risk Management Framework for Information Systems and Organizations	Risk management
NIST 800-39	Managing Information Security Risk Organization, Mission, and Information System View	Risk management
NIST 800-30	Guide for Conducting Risk Assessments	Risk management
NIST 800-63-3	Digital Identity Guidelines	IdM systems
NIST 800-63-3A	Enrollment and Identity Proofing	IdM systems
NIST 800-63-3B	Authentication and Lifecycle Management	IdM systems
NIST 800-63-3C	Federation and Assertions	IdM systems
NIST 8228	Considerations for Managing Internet of Things (IoT) Cybersecurity and Privacy Risks	IoT cybersecurity risks
NIST 800-213	IoT Device Cybersecurity Guidance for the Federal Government: Establishing IoT Device Cybersecurity Requirements	IoT cybersecurity risks
NISTIR 8200	Interagency Report on the Status of International Cybersecurity Standardization for the Internet of Things (IoT)	IoT cybersecurity risks (HIoT use case)
The European Union Agency for Network and Information Security (ENISA)	Smart Hospitals Security and Resilience for Smart Health Services and Infrastructures	Investigation of the current status of Smart Hospitals (incorporating HIoT) and related information security issues.
NISTIR 8202	Blockchain Technology Overview	Overview of Blockchain technology
NIST Cybersecurity white paper	A Taxonomic Approach to Understanding Emerging Blockchain Identity Management Systems	Blockchain identity management system: high-level conceptual explanation
EU Blockchain Observatory and Forum	Blockchain and digital identity	BC-IdM systems

evaluate the BC-IdM solution before their applications. Detailed evaluation for the technical and external aspects are problems that still need to be addressed and are considered open research problems. Performance, functional, and non-functional aspects of such solutions such as interoperability and scalability, are key factors in building reliable BC-IdM in HIoT and must be evaluated carefully. In addition, external factors such as solution acceptance, financial cost, and regulation availability also need to be evaluated. Empirical, qualitative, and quantitative studies can be conducted to fill these research gaps.

None of the proposed BC-IdM solutions for HIoT have real-life applications. This aspect affects the ability to validate the framework with real-life applications. However, four of the experts interviewed in the framework's evaluation process work on projects in developing and studying BC-IdM systems; research-based projects of BC-applications for

TABLE 22. HIoT BC-IdM requirements.

Process	Sub-process	Requirements
Identity Proofing	General	Identity proofing shall not be used to determine entitlement for gaining access. Notifying the applicant of the purpose of collecting PII. Creating records for attributes, audit logs, and evidence presented. Privacy risk mitigation and fraud mitigation measurements for additional attributes process (other than proofing, authentication, and assertion). Mechanisms used to redress applications complaints concerning the identity proofing process. Using a "practice statement" clarifies the identity proofing process, including errors and the allowed number of retries. PII protection mechanisms. Ensuring data destruction by CSP wherever it is no longer responsible for identity proofing.
	Resolution	PII collection minimization.
	Evidence Collection	CSP shall collect either one strong and superior evidence, two pieces of strong evidence, or one piece of strong with two pieces of fair evidence.
	Validation	Each piece of evidence shall be validated by CSP using by equivalent validation mechanism.
	Verification	Equivalent verification process should be used with every participant including knowledge-based verification.
Identity Authentication	General	Multi-factor authentication (or memorized secrets + single-factor authentication) Authenticators and verifiers should comply with cryptographic module requirements. Reauthentication every 12 hours or 30 minutes when inactive. Security controls equivalent to NIST 800-53 (moderate baseline). Implementing measures (Rate Limiting, Throttling) against online guessing attacks (e.g., CAPTCHA). Attestation using digital signature. Applying Verifier Impersonation Resistance against MITM. Using secure communications (mutually authenticated protocols) in case of the CSP and verifiers are different entities. Using verifier-compromise resistance authenticators (cryptographic mechanism uses public key hold by verifier and private key holds by authenticators). Using replay-resistance authenticators such as cryptographic authenticators Authentication Intent when using physical authenticators to ensure the subject response to authentication requests. Using Records Retention Policy for scheduling how long a user possesses access to data.
	Authenticator Lifecycle Management	Authenticator binding with subscriber account, including binding in the enrolment process, post-enrollment binding and renewal before expiration. Using mechanisms to deal with compromised authenticators (loss, theft, unauthorized duplication), and alternate authenticators to facilitate compromise reporting. CSP should use authenticator expiration mechanism to ensure expired authenticator can be used. Using revocation/termination mechanisms in some cases (subscriber death, lack of eligibility, subscriber request).
	Session management (After successful authentication)	Session established between subscriber's browser, application (session subject) etc. and Relying Party or CSP (session host) using a secret generated by host for such time. It should be managed using secure session management means (OAuth) sent through a secure transport channel and invalidated when the subscriber is out. When using browser cookies, it should be accessible only via HTTPS. The reauthentication process should be run periodically to ensure subscriber presence. When a session is timeout, memorized secrets (AAL2) can be used to reestablish the session. Reauthentication in federation cases does not run sessions between RP and CSP as they use separate session management technologies.
Federation	General	Th same requirements that are in Identity Proofing and Identity Authentication.
	Key management	The cryptographic mechanism is used to hinder RP impersonation of IdP in another RP
	Runtime Decisions	Mechanisms are used in which every RP and IdP use whitelist and blacklist to organize authentication requests.
	Assertion	Includes Subject (subscriber) attributes, assertion identifiers, Issuer (IdP), Audience (RP), signature, authentication time, issuance timestamp and expiration time. Assertions should be protected by including identifiers, timestamps, and nonce and should be assigned using a digital signature by the IdP and encrypted by the IdPs.

TABLE 23. HIoT application threats, vulnerabilities, and countermeasures.

Threats	vulnerabilities	Asset	Threat category	Countermeasures
T1: Device User Impersonation; HIoT used by non-authenticated users (internal adversaries). T2: HIoT type determination and HIoT tracking T3: Battery-Drain Attack T4: Signal-Jamming Flooding T5: Maintenance Compromise and Device Tampering T6: Counterfeiting leads to ownership forgery issues.	V1: Lack of HIoT device management (Weak password, HIoT default settings and HIoT device update mechanisms). V2: Lack of physical protection measures.	HIoT device	Spoofing information disclosure, denial of service, the elevation of privilege	C1: Using proxy data protection. C2: Protect host and device security, authentication, and authorization. C3: using proof-of-ownership Physical Unclonable Function (PUF) based AuthN mechanisms.
T7: Patient Data Tampering; ability to change HIoT user data and write false data caused by insider threat.	V3: lack of authentication and authorization, privacy, and encryption mechanisms.	Health Data	Tampering	C4: Using multi-factor authentication, privacy techniques such as Homomorphic encryption, differential privacy, trusted execution environment, and ABE key management mechanisms.
T8: Data Leakage	V4: unsecured interface vulnerabilities. V5: lack of input/output filtering technologies in HIoT and APIs.	Personal/Medical servers	Elevation of privilege, tampering and information disclosure	C5: Using Log systems and APIs secure protocols such as OAuth & OpenID Connect. C6: Using input/output filtering technologies with protocols.
T9: Unsecured software components at the medical server level led to application-oriented attacks.	V5: Third-party vulnerabilities and system development bugs.	Personal/Medical server	spoofing, tampering, information disclosure, and elevation of privilege	C7: Testing software against vulnerabilities and using firewalls and intrusion detection technologies.
T 10: Data eavesdropping. T 11: side-channel attack. T 12: replay attack. T 13 : Third-parties Failure. T 14 : communication modification.	V6: Lack of encryption mechanisms in storage and all layers, V7: insecure ecosystem interfaces V8: unsecured network services.	Connectivity	information disclosure, Denial of service, tampering	C8: Third-Party data distribution policy and monitoring and review of third-party services.

healthcare and IoT systems, and a project in an organization studies BC capabilities to be used in upgrading IdM systems. Their feedback was valuable to the evaluation of the framework. Even though adding HIoT users, i.e., patients and doctors, could be valuable to investigate the security concerns from a user's point of view and the acceptance of such solutions, interviewing them was outside of the scope

of this study. As discussed before, solution acceptance is an evaluation factor that must be studied; thus, this is another open research issue.

Although BC-IdM systems in this study were discussed in general, it is clear from our previous studies, more concentration was given to the BC-IdM SSI model, for two reasons:

TABLE 24. BC-IdM threats, vulnerabilities, and countermeasures.

Threats	vulnerabilities	Asset	Threat category	Countermeasures
T15: BC-IdM system governance based on full trusted authority control leads to privacy breaches caused by insider threats and compromises the confidentiality of PII. T16: Relying party misuse of patient data. T17: Relying party Impersonation and replay attack on user identity.	V9: BC-IdM system governance vulnerabilities (verifier issue).	BC-IdM	information disclosure	C9: Selecting trusted verifier carefully. C10: Minimizing personal presentation. C11: Decoupling user with identifiers by using pseudonymous identifiers C12: Using Zero-knowledge proof mechanisms. C13: Using challenge-response protocols to check private keys.
T18: Compromised data by third-party service providers in layer 2.	V10: Vulnerabilities of used off-chain technologies such IPFS, CouchDB, OrbitDB.	Layer 2 Protocol	Data tampering	C14: Security audit of the used off-chain technologies.
T19: DID wallet system attacks (DID key exposure attack, MITM attack on DID communications, DID wallet reverse engineering attack, WQL injection attack, DID DB exposure attack caused by the lack of encryption like in Indy DID DB, the elevation of privilege attack when wallet reverse attack is successful, rooting attack when attackers obtain user credential and wallet keys) T20: DID phishing and impersonation attack on the DID components communication. T21: DNS cache poisoning and pollution attack on DID document. T22: MicroService Architecture (MSA) attacks which exploit MSA vulnerabilities. T23: DID document forgery attack T24: Verifiable data registry (VDR) file system partitioning attacks T25: DID recovery process attacks.	V11: DID system vulnerabilities and defects (Latency in DID communication, verification process, and MSA vulnerabilities).	BC-IdM (DID system)	spoofing, data tampering, repudiation, information disclosure	C15: To counter DID wallet attacks, key exposure vulnerability can be controlled by using DID systems Software data and diode mechanisms. C16: MITM can be countered by using certificate pinning. C17: Login auditing is used to prevent WQL injection attacks. C18: Checking the authenticity of DID responses to prevent fishing consequences. C19: Using encryption mechanisms with DID data and wallet recovery. C20: Checking MSA-use inherited vulnerabilities.
T26: Wallets Keylogging Malware	V12: Wallet keys stored locally	Wallet	Tempering with user data	C21: Using multi-factor authentication and HW wallet to counter locally stored keys.
T27: Issuer Misuse of Tokens	V13: Counterpart tokens trust in a centralized party	tokens	tampering, information disclosure	C22: Using reputation decentralized systems to improve trust.
T28: Oracle data compromise leads to compromised application results. T29: Data Privacy leakage in Oracle systems.	V14: Trusted party reliance (centralized design).	Oracles	information disclosure and data tempering	C23: Checking oracles for security vulnerabilities and use mitigation solutions.

- Firstly, resource constraints, as most BC-IdM studies focus on the SSI model.
- Secondly, as it is, the model aligns with the main concept and feature of decentralized identities, i.e., identity owners in control of their identities.

As the technology under investigation is evolving (BC-IdM), results from this study are expected to be updated. Several initiatives concerning regulations of BC application in general and BC-IdM are undergoing, which might change the regulation-related issues of such systems. This work contributes to the same direction by covering the cybersecurity risk management and evaluation aspects, which, as a result, supports the development of reliable BC-IdM solutions for HIIoT systems.

IX. CONCLUSION

This article evaluated published findings from previous studies that identified cybersecurity risk management framework and evaluation factors for HIIoT BC-IdM systems by 1) interviewing thirteen experts chosen systematically from HIIoT security, BC, IdM systems, and cybersecurity risk management domains concerning the framework's main components, and 2) getting feedback and consensus via a questionnaire on the details of the framework and assigning weights to the identified evaluation factors.

Doing so, this work answered the main research question: “What is a reliable cybersecurity risk management and evaluation framework for BC-based IdM in HIoT?” The developed framework in this research will play a substantial role in evaluating BC-IdM in HIoT systems in general and

managing cybersecurity risk in particular. Albeit this work focused more on the cybersecurity risk management process. It identified the whole evaluation factors for such systems and assessed them via interviewing experts following the Delphi method.

This work contributes to the literature at both theoretical and practical levels. At the theoretical level, it proposed a reference framework needed to manage cybersecurity risks and evaluate BC-IdM in HIoT. The framework includes main evaluation factors, main cybersecurity phases, and steps that show required team members, standards, assets, entities, requirements, controls, principles, and policies. Also, it shows threats, vulnerabilities, risks, and countermeasures. Even though this framework focuses on the BC-IdM system in HIoT, its content applies to BC-IdM systems in general as the considerations of the HIoT systems is a further step. At the practical level, the applicability of the framework can be shown by conducting an evaluation of HIoT BC-IdM projects, in which compliance with the framework can show whether there is a need for improvements in HIoT BC-IdM projects. A real-life scenario is planned to be applied in the future where the framework is used to check its applicability and effectiveness. As such technology is still evolving, it should be used in practical work and continuously improved whenever needed.

APPENDIX A

EXPERT DETAILS

Table 16 shows details of the experts who participated in this research.

TABLE 25. BC threats, vulnerabilities, and countermeasures.

Threats	Vulnerabilities	Asset	Threat category	Countermeasures
T30: Centralization of control in BC private network leads to external and insider threats, and mandates using VPN, which leads to use public network/ internet services.	V15: P2P network design vulnerabilities	BC (network)	information disclosure and elevation of privilege	C24: Update system and monitor network users regularly using intrusion detection systems. C25: Using mechanisms decreases trust (Multiple-factor authentication) and following best practices to mitigate insider threats.
T31: Exploit public P2P network protocol vulnerabilities to run generic communication attacks such as Denial of Service Attack, Domain Name System (DNS), and routing protocol attacks, which lead to connectivity DoS.	V16:P2P network design vulnerabilities	BC (network)	Denial of Service	C26: using DNS Security mechanisms. C27: Use whitelist nodes for the peering process. C28: Use secure consensus mechanisms.
T32: Cryptographic threats caused by powerful computing such as quantum computing.	V17: Cryptographic vulnerabilities	BC (network)	Denial of service	C29: Using quantum computing-safe cryptographic mechanisms.
T33: Double spending attack and Race attack by exploiting the delay in user transaction verification to access the transaction data. T34: 51% attack or 1/3 Byzantine nodes T28: Goldfinger attack by paying miners to write empty blocks in BC-based Proof of Stack (PoS) Consensus Mechanism T35: Breaking Consensus Assumptions T36: Time De-synchronization Attacks T37: Attacks on distributed sharding. (Threats are inherited from consensus mechanisms)	V18: Consensus mechanisms slow finality time vulnerability V19: Violating consensus assumptions in Consensus mechanisms. V20: Partitioning of the consensus power in sharding protocols.	BC (Consensus mechanisms)	Tampering and information disclosure	C30: Using fast finality Consensus mechanisms to tackle double spending. C31: Using incentive mechanisms to tackle 51 % attack C32: Using whitelist of trusted peers and Timestamping mechanisms to tackle de-synchronization attacks. C33: Using asynchronous protocols to tackle breaking consensus assumptions issue. C34: Distribute node participating in sharding process randomly.
T38: Program function vulnerabilities, such as short address attack in Ethereum VM, where attackers exploit vulnerabilities in the wallet short address to manipulate transaction data.	V21: BC virtual machine (VM) implementation and programming language vulnerabilities	BC (Virtual machine and programming language)	tampering and information disclosure	C35: Only using safe VM and languages. C36: using bug testing and audit tools.
T39: User Identity Exposure and Data Exposure	V22: SC Data transparency and deanonymization	BC (Transactions)	Information Disclosure	C37: Using noninteractive zero-knowledge proofs, multiparty computation (MPC), blinding signatures, layered encryption, and Ring signatures provide an unlikability to users. C38: Using trusted transaction managers, trusted hardware, and MPC to preserve the privacy of SC.
T40: External and internal threats (SC developers), such as reentrancy attacks in Ethereum SCs.	V23: SC programming language (on-chain logic) vulnerabilities	BC (Smart Contracts)	Tampering, information disclosure, and Elevation of privilege	C39: Only using safe SC language, using static and dynamic testing tools, using formal verification methods, using semantic audits tools, and best practices design patterns.

APPENDIX B
BLOCKCHAIN PLATFORMS COMPARISON

Table 17

APPENDIX C
IdM MODELS COMPARISON

Table 18

APPENDIX D
BC-IdM TOOLS COMPARISON

Table 19

APPENDIX E
HIIoT BC-IdM MAIN AND SECONDARY ASSETS

Table 20

APPENDIX F
INTERNATIONAL CYBERSECURITY RISK MANAGEMENT STANDARDS

Table 21

APPENDIX G
HIIoT BC-IdM REQUIREMENTS

Table 22

APPENDIX H
HIIoT APPLICATION THREATS, VULNERABILITIES, AND COUNTERMEASURES CLASSIFIED INTO ASSETS

Table 23

APPENDIX I
BC-IdM THREATS, VULNERABILITIES, AND COUNTERMEASURES CLASSIFIED INTO ASSETS

Table 24

APPENDIX J
BC THREATS, VULNERABILITIES, AND COUNTERMEASURES CLASSIFIED INTO ASSETS

Table 25

REFERENCES

[1] B. Alamri, K. Crowley, and I. Richardson, "Cybersecurity risk management framework for blockchain identity management systems in health IoT," *Sensors*, vol. 23, no. 1, p. 218, Dec. 2022. [Online]. Available: <https://www.mdpi.com/1424-8220/23/1/218>

[2] B. Alamri, K. Crowley, and I. Richardson, "Blockchain-based identity management systems in health IoT: A systematic review," *IEEE Access*, vol. 10, pp. 59612–59629, 2022. [Online]. Available: <https://ieeexplore.ieee.org/document/9789115/>

[3] B. Alamri, K. Crowley, and I. Richardson, "Evaluation factors for blockchain identity management systems," in *Proc. Int. Conf. Cybersecurity, Situational Awareness Social Media*, C. Onwubiko, P. Rosati, A. Rege, A. Erola, X. Bellekens, H. Hindy, and M. G. Jaatun, Eds. Singapore: Springer, 2024, pp. 49–74.

[4] M. Hogan and B. Piccarreta, "Interagency report on the status of international cybersecurity standardization for the Internet of Things (IoT)," NIST, Gaithersburg, MD, USA, Tech. Rep. 8200, 2015, doi: [10.6028/NIST.IR.8200](https://doi.org/10.6028/NIST.IR.8200).

[5] M. Crosby, P. Pattanayak, S. Verma, and V. Kalyanaraman, "Blockchain technology: Beyond bitcoin," *Appl. Innov.*, vol. 2, nos. 6–10, p. 71, 2016.

[6] F. Tschorsch and B. Scheuermann, "Bitcoin and beyond: A technical survey on decentralized digital currencies," *IEEE Commun. Surveys Tuts.*, vol. 18, no. 3, pp. 2084–2123, 3rd Quart., 2016.

[7] R. Colomo-Palacios, M. Sánchez-Gordón, and D. Arias-Aranda, "A critical review on blockchain assessment initiatives: A technology evolution viewpoint," *J. Softw., Evol. Process*, vol. 32, no. 11, p. e2272, Nov. 2020.

- [8] H. Wang, Y. Wang, Z. Cao, Z. Li, and G. Xiong, "An overview of blockchain security analysis," in *Proc. 15th Int. Annu. Conf.*, Beijing, China. Singapore: Springer, Aug. 2019, pp. 55–72.
- [9] H. Guo and X. Yu, "A survey on blockchain technology and its security," *Blockchain, Res. Appl.*, vol. 3, no. 2, Jun. 2022, Art. no. 100067.
- [10] M. A. Ferrag, M. Derdour, M. Mukherjee, A. Derhab, L. Maglaras, and H. Janicke, "Blockchain technologies for the Internet of Things: Research issues and challenges," *IEEE Internet Things J.*, vol. 6, no. 2, pp. 2188–2204, Apr. 2019.
- [11] J. Brogan, I. Baskaran, and N. Ramachandran, "Authenticating health activity data using distributed ledger technologies," *Comput. Struct. Biotechnol. J.*, vol. 16, pp. 257–266, Jan. 2018. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S2001037018300345>
- [12] Y. Zou, T. Meng, P. Zhang, W. Zhang, and H. Li, "Focus on blockchain: A comprehensive survey on academic and application," *IEEE Access*, vol. 8, pp. 187182–187201, 2020.
- [13] A. Tandon, A. Dhir, A. K. M. N. Islam, and M. Mäntymäki, "Blockchain in healthcare: A systematic literature review, synthesizing framework data and future research agenda," *Comput. Ind.*, vol. 122, Nov. 2020, Art. no. 103290. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S0166361520305248>
- [14] B. Houtan, A. S. Hafid, and D. Makrakis, "A survey on blockchain-based self-sovereign patient identity in healthcare," *IEEE Access*, vol. 8, pp. 90478–90494, 2020.
- [15] M. Mamdouh, A. I. Awad, A. A. M. Khalaf, and H. F. A. Hamed, "Authentication and identity management of IoT devices: Achievements, challenges, and future directions," *Comput. Secur.*, vol. 111, Dec. 2021, Art. no. 102491. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S0167404821003151>
- [16] Z. Zheng, S. Xie, H. Dai, X. Chen, and H. Wang, "An overview of blockchain technology: Architecture, consensus, and future trends," in *Proc. IEEE Int. Congr. Big Data*, Jun. 2017, pp. 557–564.
- [17] A. Ouaddah, H. Mousannif, A. A. Elkalam, and A. Ait Ouahman, "Access control in the Internet of Things: Big challenges and new opportunities," *Comput. Netw.*, vol. 112, pp. 237–262, Jan. 2017. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S1389128616303735>
- [18] I. Indu, P. M. R. Anand, and V. Bhaskar, "Identity and access management in cloud environment: Mechanisms and challenges," *Eng. Sci. Technol., Int. J.*, vol. 21, no. 4, pp. 574–588, Aug. 2018. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S2215098617316750>
- [19] S. V. Sudarsan, O. Schelén, and U. Bodin, "Survey on delegated and self-contained authorization techniques in CPS and IoT," *IEEE Access*, vol. 9, pp. 98169–98184, 2021.
- [20] L. Lesavre, "A taxonomic approach to understanding emerging blockchain identity management systems," Nat. Inst. Standards Technol., Gaithersburg, MD, USA, Tech. Rep. CSWP9, Jan. 2020. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.01142020.pdf>
- [21] S. E. Haddouti and M. D. E.-C. El Kettani, "Analysis of identity management systems using blockchain technology," in *Proc. Int. Conf. Adv. Commun. Technol. Netw. (CommNet)*, Apr. 2019, pp. 1–7.
- [22] M. Kuperberg, "Blockchain-based identity management: A survey from the enterprise and ecosystem perspective," *IEEE Trans. Eng. Manag.*, vol. 67, no. 4, pp. 1008–1027, Nov. 2020.
- [23] W. L. Sim, H. N. Chua, and M. Tahir, "Blockchain for identity management: The implications to personal data protection," in *Proc. IEEE Conf. Appl., Inf. Netw. Secur. (AINS)*, Nov. 2019, pp. 30–35.
- [24] P. J. Taylor, T. Dargahi, A. Dehghantanha, R. M. Parizi, and K.-K.-R. Choo, "A systematic literature review of blockchain cyber security," *Digit. Commun. Netw.*, vol. 6, no. 2, pp. 147–156, May 2020. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S2352864818301536>
- [25] S. Alzahrani, T. Daim, and K. R. Choo, "Assessment of the blockchain technology adoption for the management of the electronic health record systems," *IEEE Trans. Eng. Manag.*, vol. 70, no. 8, pp. 2846–2863, Aug. 2023.
- [26] S. Balasubramanian, V. Shukla, J. S. Sethi, N. Islam, and R. Saloum, "A readiness assessment framework for blockchain adoption: A healthcare case study," *Technological Forecasting Social Change*, vol. 165, Apr. 2021, Art. no. 120536.
- [27] R. Skinner, R. R. Nelson, W. W. Chin, and L. Land, "The delphi method research strategy in studies of information systems," *Commun. Assoc. Inf. Syst.*, vol. 37, pp. 31–63, Jan. 2015.
- [28] B. J. Oates, M. Griffiths, and R. McLean, *Researching Information Systems and Computing*. Newbury Park, CA, USA: Sage, 2022.
- [29] C. R. Boddy, "Sample size for qualitative research," *Qualitative Market Res., Int. J.*, vol. 19, no. 4, pp. 426–432, Sep. 2016.
- [30] M. Hennink and B. N. Kaiser, "Sample sizes for saturation in qualitative research: A systematic review of empirical tests," *Social Sci. Med.*, vol. 292, Jan. 2022, Art. no. 114523.
- [31] M. Castillo-Montoya, "Preparing for interview research: The interview protocol refinement framework," *Qualitative Rep.*, vol. 21, no. 5, pp. 811–831, 2016.
- [32] BandarAlamri/Experts-Interviews-Questionnaire-Materials: Contains the Interview Questions, Scripts, Questionnaire, and Assigned Values for All Factors. Accessed: Mar. 15, 2023. [Online]. Available: <https://github.com/BandarAlamri/Experts-interviews-questionnaire-materials>
- [33] M. Singh and M. Pant, "A review of selected weighing methods in MCDM with a case study," *Int. J. Syst. Assurance Eng. Manage.*, vol. 12, no. 1, pp. 126–144, Feb. 2021.
- [34] G. O. Odu, "Weighting methods for multi-criteria decision making technique," *J. Appl. Sci. Environ. Manage.*, vol. 23, no. 8, p. 1449, Sep. 2019.
- [35] S. Nanayakkara, M. N. N. Rodrigo, S. Perera, G. T. Weerasuriya, and A. A. Hijazi, "A methodology for selection of a blockchain platform to develop an enterprise system," *J. Ind. Inf. Integr.*, vol. 23, Sep. 2021, Art. no. 100215. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S2452414X21000169>
- [36] J. Polge, J. Robert, and Y. Le Traon, "Permissioned blockchain frameworks in the industry: A comparison," *ICT Exp.*, vol. 7, no. 2, pp. 229–233, Jun. 2021.
- [37] B. Alamri, I. T. Javed, and T. Margaria, "A GDPR-compliant framework for IoT-based personal health records using blockchain," in *Proc. 11th IFIP Int. Conf. New Technol., Mobility Secur. (NTMS)*, Apr. 2021, pp. 1–5.
- [38] (2011). *Managing Information Security Risk*. Nat. Inst. Standards Technol. Gaithersburg, MD, USA. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-39.pdf>
- [39] (2012). *Guide for Conducting Risk Assessments*. Nat. Inst. Standards Technol., Gaithersburg, MD, USA. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf>
- [40] E. Paintsil and L. Fritsch, "A taxonomy of privacy and security risks contributing factors," in *Privacy and Identity Management for Life*. Berlin, Germany: Springer, 2011, pp. 52–63.
- [41] E. Paintsil, "Evaluation of privacy and security risks analysis construct for identity management systems," *IEEE Syst. J.*, vol. 7, no. 2, pp. 189–198, Jun. 2013.
- [42] V. Vakhter, B. Soysal, P. Schaumont, and U. Guler, "Threat modeling and risk analysis for miniaturized wireless biomedical devices," *IEEE Internet Things J.*, vol. 9, no. 15, pp. 13338–13352, Aug. 2022.
- [43] P. C. Paul, J. Loane, F. McCaffery, and G. Regan, "Towards design and development of a data security and privacy risk management framework for WBAN based healthcare applications," *Appl. Syst. Innov.*, vol. 4, no. 4, p. 76, Oct. 2021. [Online]. Available: <https://www.mdpi.com/2571-5577/4/4/76>
- [44] A. Shostack, *Threat Modeling: Designing for Security*. Hoboken, NJ, USA: Wiley, 2014.
- [45] V. Schlatt, T. Guggenberger, J. Schmid, and N. Urbach, "Attacking the trust machine: Developing an information systems research agenda for blockchain cybersecurity," *Int. J. Inf. Manage.*, vol. 68, Feb. 2023, Art. no. 102470.
- [46] J. T. Force, "NIST special publication 800–37 risk management framework for information systems and organizations a system life cycle approach for security and privacy JOINT TASK FORCE," NIST, Gaithersburg, MD, USA, Tech. Rep. 800-37, 2017, doi: 10.6028/NIST.SP.800-37r2.
- [47] P. A. Grassi, M. E. Garcia, and J. L. Fenton, "Digital identity guidelines: Revision 3," Nat. Inst. Standards Technol., Gaithersburg, MD, USA, Tech. Rep. 800-63-3, Jun. 2017. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-63-3.pdf>
- [48] (Sep. 2020). *Security and Privacy Controls for Information Systems and Organizations*. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>
- [49] K. Boeckl, M. Fagan, W. Fisher, N. Lefkowitz, K. N. Megaw, E. Nadeau, D. G. O'Rourke, B. Piccarreta, and K. Scarfone, "Considerations for managing Internet of Things (IoT) cybersecurity and privacy risks," Nat. Inst. Standards Technol., Gaithersburg, MD, USA, Tech. Rep. 8228, Jun. 2019. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/ir/2019/NIST.IR.8228.pdf>

- [50] *Cyber Security and Resilience for Smart Hospitals—Enisa*. Accessed: Jan. 22, 2023. [Online]. Available: <https://www.enisa.europa.eu/publications/cyber-security-and-resilience-for-smart-hospitals>
- [51] D. Yaga, P. Mell, N. Roby, and K. Scarfone, "Blockchain technology overview," 2019, *arxiv:1906.11078*.
- [52] The European Union Blockchain and Observatory and Forum. (Oct. 1018). *Blockchain and GDPR*. [Online]. Available: https://www.eublockchainforum.eu/sites/default/files/reports/20181016_report_gdpr.pdf
- [53] *Blockchain and Digital Identity | EUBlockchain*. Accessed: Jan. 17, 2023. [Online]. Available: <https://www.eublockchainforum.eu/reports/blockchain-and-digital-identity>
- [54] L. Lesavre, P. Varin, and D. Yaga, "Blockchain networks: Token design and management overview," Nat. Inst. Standards Technol., Gaithersburg, MD, USA, Tech. Rep. 8301, Feb. 2021. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/ir/2021/NIST.IR.8301.pdf>
- [55] V. C. Hu. (2022). *Blockchain for Access Control Systems*. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/ir/2022/NIST.IR.8403.pdf>
- [56] P. A. Grassi, J. L. Fenton, N. B. Lefkowitz, J. M. Danker, Y.-Y. Choong, K. K. Greene, and M. F. Theofanos, "Digital identity guidelines: Enrollment and identity proofing," Nat. Inst. Standards Technol., Gaithersburg, MD, USA, Tech. Rep. 800-63 A, Jun. 2017. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-63a.pdf>
- [57] *Interoperable Digital Identity and Patient Matching*. Accessed: Jan. 22, 2023. [Online]. Available: <http://build.fhir.org/ig/HL7/fhir-identity-matching-ig/index.html>
- [58] P. A. Grassi, J. P. Richer, S. K. Squire, J. L. Fenton, E. M. Nadeau, N. B. Lefkowitz, J. M. Danker, Y.-Y. Choong, K. K. Greene, and M. F. Theofanos, "Digital identity guidelines: Federation and assertions," Nat. Inst. Standards Technol., Gaithersburg, MD, USA, Tech. Rep. 800-63 C, Jun. 2017. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-63c.pdf>
- [59] Y. Sun, F. P.-W. Lo, and B. Lo, "Security and privacy for the Internet of Medical Things enabled healthcare systems: A survey," *IEEE Access*, vol. 7, pp. 183339–183355, 2019.
- [60] C. Pattiyanon and T. Aoki, "Compliance SSI system property set to laws, regulations, and technical standards," *IEEE Access*, vol. 10, pp. 99370–99393, 2022.
- [61] V. Malamas, F. Chantzis, T. K. Dasaklis, G. Stergiopoulos, P. Kotzanikolaou, and C. Douligeris, "Risk assessment methodologies for the Internet of Medical Things: A survey and comparative appraisal," *IEEE Access*, vol. 9, pp. 40049–40075, 2021.
- [62] M. Nieves, K. Dempsey, and V. Y. Pillitteri, "An introduction to information security," Nature Inst. Standards Technol., Gaithersburg, MD, USA, Tech. Rep. 800-12, Jun. 2017. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-12r1.pdf>
- [63] I. Homoliak, S. Venugopalan, D. Reijnders, Q. Hum, R. Schumi, and P. Szalachowski, "The security reference architecture for blockchains: Toward a standardized model for studying vulnerabilities, threats, and defenses," *IEEE Commun. Surveys Tuts.*, vol. 23, no. 1, pp. 341–390, 1st Quart., 2021.
- [64] L. Wang, Y. Ali, S. Nazir, and M. Niazi, "ISA evaluation framework for security of Internet of Health Things system using AHP-TOPSIS methods," *IEEE Access*, vol. 8, pp. 152316–152332, 2020.
- [65] H. L'Amrani, B. E. Berroukech, Y. E. B. E. Idrissi, and R. Ajhoun, "Identity management systems: Laws of identity for models evaluation," *Colloq. Inf. Sci. Technol.*, pp. 736–740, Jul. 2016.
- [66] J. Leskinen, "Evaluation criteria for future identity management," in *Proc. IEEE 11th Int. Conf. Trust, Secur. Privacy Comput. Commun.*, Jun. 2012, pp. 801–806.



BANDAR ALAMRI received the B.S. degree in computer information systems from Taibah University, Medina, Saudi Arabia, the M.S. degree in computer science (cybersecurity) from the University of Bedfordshire, Luton, U.K., and the Ph.D. degree in computer science and information systems from the University of Limerick, Ireland. He works as a Cybersecurity Specialist and a Researcher. His research interests include studying the cybersecurity and GRC of emerging technologies, such as blockchain, and using blockchain in identity management systems in the Internet of Things and e-health applications.



ITA RICHARDSON is currently a Professor of software quality with the University of Limerick and the Deputy Director of Lero—the Science Foundation Ireland Research Centre for Software. She has supervised 23 Ph.D. students to completion and has over 200 publications, many of which focus on digital health and regulation in healthcare software. She has received research funding from SFI, European Union, the Irish Research Council, Enterprise Ireland, and many international and indigenous companies, including De Puy, Ocuco, and IBM.



KATIE CROWLEY received the B.Sc. degree in computer science from University College Cork, the M.Sc. degree from the University of Limerick, and the Ph.D. degree in computer science from University College Cork. She is currently a Lecturer and a Researcher with the Department of Computer Science and Information Systems, University of Limerick. She is also a member of Lero, the SFI Research Centre for Software, and the Health Research Institute. She is also the Course Director of the Master's Program in Health Informatics. Her research interests include affective computing, human–computer interaction, and health information technology.

...